

CNIC-Based Health Card System

Complete System Design, Requirements, Profiles & UML Reference Document

Version	1.0
Initiative	Pakistan Digital Health Initiative
Standards	HL7 FHIR R4 · ICD-10 · SNOMED CT · LOINC · HIPAA
Compliance	PDPB 2023 · One Patient One ID
Platform	Flutter (Mobile) · React (Web) · PostgreSQL · HAPI FHIR

16 Sections	140 Functional Req.	28 DB Tables	77 Use Cases	25 Notification Types
----------------	------------------------	-----------------	-----------------	-----------------------------

CNIC-Based Health Card System

Complete System Design, Requirements, Profiles, and UML Reference Document

Version 1.0 | Pakistan Digital Health Initiative

TABLE OF CONTENTS

1. Executive Summary
2. System Overview and Architecture
3. User Profiles — Complete Field Definitions
4. Complete Database Schema
5. Functional Requirements
6. Non-Functional Requirements
7. User Use Cases
8. Entity Relationship Descriptions (UML Source)
9. Data Flow Descriptions (Sequence Diagram Source)
10. State Machines
11. API Surface Overview
12. Security Model
13. Role and Permission Matrix
14. Notification and Event Catalogue
15. Audit and Compliance Rules
16. Implementation Phases

SECTION 1: EXECUTIVE SUMMARY

This document is the complete system design specification for the CNIC-Based Health Card System, a centralized digital health records platform for Pakistan. The platform links every citizen's medical history to their Computerized National Identity Card (CNIC) number, enabling continuity of care across any clinic, hospital, or telemedicine provider in the country.

The system provides five distinct user roles: Patient, Doctor, Lab Worker, Receptionist, and System Admin. Each role interacts with a shared clinical data layer through strictly enforced permission boundaries. Clinical data is modelled on the HL7 FHIR standard to ensure future interoperability with national and international health systems.

The system is built for a mobile-first population, with Flutter applications for Android and iOS serving patients, doctors, lab workers, and receptionists, and a separate web application serving system administrators.

Alignment targets include Pakistan's One Patient One ID initiative, the Personal Data Protection Bill (PDPB) 2023, and international standards including HIPAA, HL7 FHIR R4, ICD-10, SNOMED CT, and LOINC.

SECTION 2: SYSTEM OVERVIEW AND ARCHITECTURE

2.1 System Boundaries

The system consists of the following major components:

- Patient Mobile Application (Flutter, Android + iOS)
- Doctor Mobile Application (Flutter, Android + iOS)
- Lab Worker Mobile Application (Flutter, Android + iOS, lightweight)
- Receptionist Module (Flutter, shared app with role-based routing)
- Admin Web Portal (React, web browser)
- API Gateway (single entry point, handles auth validation, rate limiting, routing)
- Identity and Auth Service (Supabase Auth / Keycloak, OpenID Connect, JWT)
- Clinical Data Service (FHIR-mapped Postgres tables via REST)
- FHIR Server (HAPI FHIR, for structured FHIR resource storage and subscriptions)
- Notification Service (Firebase Cloud Messaging, Apple Push Notification Service, SMS gateway)
- File Storage Service (Supabase Storage / AWS S3, for lab reports, documents)
- NADRA Integration Layer (CNIC verification API)
- Audit Service (append-only audit log, never updatable)
- Analytics Service (aggregate reporting, no PII)
- Background Job Scheduler (medication reminders, appointment reminders, refill alerts)

2.2 Architectural Pattern

The system uses a modular monolith pattern for the prototype, transitioning to microservices for production. All clinical data is stored as or mapped to FHIR R4 resources. The application layer translates between FHIR resources and mobile-friendly REST JSON responses.

Data residency: All personally identifiable information and health data must be stored on servers physically located in Pakistan (PDPB 2023 requirement). Cloud provider region: AWS ap-south-1 (Mumbai) as nearest available zone, pending a local Pakistani data center option.

2.3 Technology Stack Decisions

Database: PostgreSQL 15 with Row Level Security (RLS). Two schemas — `auth_layer` and `clinical_layer` — enforced at the database level.

Backend: Node.js with Express for application services. HAPI FHIR Java server for FHIR resource management, deployed as a Docker container alongside the main application.

Mobile: Flutter 3.x for all mobile applications. Single codebase, role-based navigation via GoRouter.

Admin: React 18 with TypeScript. No mobile requirement for admin.

Auth: Supabase Auth for prototype. Keycloak for production (self-hosted, supports SMART on FHIR).

Storage: Supabase Storage (prototype), AWS S3 with server-side AES-256 encryption (production).

Cache: Redis for session data, rate limiting counters, OTP codes (TTL 5 minutes), and CNIC verification cache (TTL 24 hours).

Search: PostgreSQL full-text search for prototype. Elasticsearch for production patient search.

Message queue: RabbitMQ for event-driven notifications and background jobs.

Monitoring: Prometheus + Grafana for metrics. ELK stack (Elasticsearch, Logstash, Kibana) for log aggregation.

SECTION 3: USER PROFILES — COMPLETE FIELD DEFINITIONS

3.1 Base Profile (all users inherit this)

Table name: profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, default gen_random_uuid()	Internal system ID, used as FK everywhere
auth_user_id	UUID	UNIQUE, NOT NULL, FK auth.users(id)	Links to Supabase/Keycloak auth identity
cnic	VARCHAR(13)	UNIQUE, NOT NULL, CHECK(cnic ~ '^d{13}\$')	Pakistan CNIC, 13 digits, no dashes
cnic_verified	BOOLEAN	NOT NULL, DEFAULT false	Set true after NADRA API confirms the CNIC
cnic_verified_at	TIMESTAMPTZ	NULLABLE	Timestamp of NADRA verification
full_name	VARCHAR(255)	NOT NULL	Full legal name as per CNIC
date_of_birth	DATE	NOT NULL	As per CNIC
gender	VARCHAR(10)	NOT NULL, CHECK IN ('male','female','other')	As per CNIC
phone_primary	VARCHAR(15)	NOT NULL	Primary mobile number, used for OTP
phone_secondary	VARCHAR(15)	NULLABLE	Optional backup number
email	VARCHAR(255)	NULLABLE, UNIQUE where not null	Optional, used for non-OTP notifications
profile_photo_url	TEXT	NULLABLE	URL in file storage, optional
role	VARCHAR(20)	NOT NULL, CHECK IN ('patient','doctor','lab_worker','receptionist','admin')	Primary role
status	VARCHAR(20)	NOT NULL, DEFAULT 'pending', CHECK IN ('active','pending','suspended','rejected','deactivated')	Account lifecycle status
status_reason	TEXT	NULLABLE	Admin note explaining status change
status_changed_at	TIMESTAMPTZ	NULLABLE	When status last changed
status_changed_by	UUID	NULLABLE, FK profiles(id)	Admin who changed the status
language_preference	VARCHAR(10)	NOT NULL, DEFAULT 'en', CHECK IN ('en','ur')	Urdu or English UI preference
notification_push_enabled	BOOLEAN	DEFAULT true	FCM/APNS push on/off
notification_sms_enabled	BOOLEAN	DEFAULT true	SMS alerts on/off
notification_email_enabled	BOOLEAN	DEFAULT false	Email alerts on/off
last_login_at	TIMESTAMPTZ	NULLABLE	Most recent successful login
last_login_ip	INET	NULLABLE	IP address of last login

Field	Type	Constraints	Description
last_login_device	TEXT	NULLABLE	Device fingerprint string
failed_login_attempts	INTEGER	DEFAULT 0	Resets on successful login
locked_until	TIMESTAMPZ	NULLABLE	Account lock expiry after too many failures
mfa_enabled	BOOLEAN	DEFAULT true	MFA cannot be disabled for doctors
mfa_method	VARCHAR(20)	DEFAULT 'sms_otp', CHECK IN ('sms_otp','email_otp','totp','biometric')	Active MFA method
created_at	TIMESTAMPZ	DEFAULT now()	Registration timestamp
updated_at	TIMESTAMPZ	DEFAULT now()	Last profile update
deactivated_at	TIMESTAMPZ	NULLABLE	When account was deactivated (soft delete)
gdpr_consent_given	BOOLEAN	DEFAULT false	PDPB / data consent flag
gdpr_consent_given_at	TIMESTAMPZ	NULLABLE	When consent was given
gdpr_consent_version	VARCHAR(10)	NULLABLE	Which consent form version they accepted

3.2 Patient Extended Profile

Table name: patient_profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, FK profiles(id)	Same ID as base profile
blood_group	VARCHAR(5)	NULLABLE, CHECK IN ('A+', 'A-', 'B+', 'B-', 'AB+', 'AB-', 'O+', 'O-', 'unknown')	Self-reported or lab-confirmed
blood_group_confirmed	BOOLEAN	DEFAULT false	True if confirmed by lab result in system
height_cm	DECIMAL(5,2)	NULLABLE	In centimetres
weight_kg	DECIMAL(5,2)	NULLABLE	In kilograms, most recent self-reported
address_street	TEXT	NULLABLE	Home address line
address_city	VARCHAR(100)	NULLABLE	City
address_province	VARCHAR(50)	NULLABLE, CHECK IN ('punjab', 'sindh', 'kp k', 'balochistan', 'gilgit_baltistan', 'azad_kashmir', 'islamabad')	Province
address_postal_code	VARCHAR(10)	NULLABLE	Postal code
emergency_contact_name	VARCHAR(255)	NULLABLE	Emergency contact full name
emergency_contact_phone	VARCHAR(15)	NULLABLE	Emergency contact phone
emergency_contact_relation	VARCHAR(50)	NULLABLE	Relation to patient
marital_status	VARCHAR(20)	NULLABLE, CHECK IN ('single', 'married', 'divorced', 'widowed', 'unknown')	Optional
occupation	VARCHAR(100)	NULLABLE	Self-reported occupation
insurance_provider	VARCHAR(255)	NULLABLE	Health insurance company name
insurance_policy_number	VARCHAR(100)	NULLABLE	Policy number

Field	Type	Constraints	Description
insurance_valid_until	DATE	NULLABLE	Policy expiry
qr_token	UUID	UNIQUE, NOT NULL, DEFAULT gen_random_uuid()	Opaque token encoded in QR code, not the CNIC
qr_token_issued_at	TIMESTAMPTZ	DEFAULT now()	When this QR token was generated
qr_token_invalidated	BOOLEAN	DEFAULT false	True if QR was reported lost/stolen
health_card_number	VARCHAR(20)	UNIQUE, NOT NULL	Human-readable card number (e.g. HC-2024-00001234)
known_allergies	TEXT	NULLABLE	Free text, also stored as structured Allergy resources
chronic_conditions_summary	TEXT	NULLABLE	Denormalised summary for quick display, derived from Condition table
privacy_hide_psychiatry	BOOLEAN	DEFAULT false	Hide psychiatry encounters by default
privacy_hide_reproductive	BOOLEAN	DEFAULT false	Hide reproductive health by default
privacy_hide_substance	BOOLEAN	DEFAULT false	Hide substance-related encounters by default
allow_doctor_record_request	BOOLEAN	DEFAULT true	Doctors can request access to hidden records
allow_research_data_use	BOOLEAN	DEFAULT false	Anonymised data may be used for public health research
preferred_pharmacy	VARCHAR(255)	NULLABLE	Preferred pharmacy name
preferred_pharmacy_location	VARCHAR(255)	NULLABLE	Pharmacy address or branch
organ_donor	BOOLEAN	DEFAULT false	Organ donor consent
created_at	TIMESTAMPTZ	DEFAULT now()	Profile creation
updated_at	TIMESTAMPTZ	DEFAULT now()	Last update

3.3 Doctor Extended Profile

Table name: doctor_profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, FK profiles(id)	Same ID as base profile
pmdc_number	VARCHAR(50)	UNIQUE, NOT NULL	Pakistan Medical and Dental Council registration number
pmdc_verified	BOOLEAN	DEFAULT false	Admin confirmed PMDC number is valid
pmdc_verified_at	TIMESTAMPTZ	NULLABLE	When PMDC was verified
pmdc_verified_by	UUID	NULLABLE, FK profiles(id)	Which admin verified
pmdc_expiry_date	DATE	NULLABLE	PMDC registration renewal date
specialization_primary	VARCHAR(100)	NOT NULL	Primary specialty (e.g. Cardiology)
specialization_secondary	VARCHAR(100)	NULLABLE	Optional second specialty
qualification_mbbs	BOOLEAN	DEFAULT false	Holds MBBS
qualification_md	BOOLEAN	DEFAULT false	Holds MD

Field	Type	Constraints	Description
qualification_fcps	BOOLEAN	DEFAULT false	Holds FCPS
qualification_other	TEXT	NULLABLE	Other qualifications free text
graduation_year	SMALLINT	NULLABLE	Year of primary degree completion
graduation_institution	VARCHAR(255)	NULLABLE	Medical school name
years_of_experience	SMALLINT	NULLABLE	Self-reported, shown on profile
consultation_fee_pkr	DECIMAL(10,2)	NULLABLE	Standard fee in PKR, displayed to patients
consultation_duration_minutes	SMALLINT	DEFAULT 15	Default slot length for scheduling
accepts_walk_ins	BOOLEAN	DEFAULT false	Whether walk-in patients are accepted
accepts_telehealth	BOOLEAN	DEFAULT false	Whether the doctor does video consultations
telehealth_platform_url	TEXT	NULLABLE	Link to their telehealth setup if external
bio	TEXT	NULLABLE	Doctor's public biography
languages_spoken	TEXT[]	NULLABLE	Array: ['urdu','english','punjabi'] etc
profile_public	BOOLEAN	DEFAULT true	Whether patients can find them in search
is_available	BOOLEAN	DEFAULT true	Toggle to go unavailable without deactivating
average_rating	DECIMAL(3,2)	NULLABLE	Computed from appointment_reviews, updated by trigger
total_reviews	INTEGER	DEFAULT 0	Count of reviews
total_patients_seen	INTEGER	DEFAULT 0	Running count updated by trigger on encounter finalize
digital_signature_url	TEXT	NULLABLE	Doctor's digital signature image for prescriptions
prescription_header	TEXT	NULLABLE	Custom header text for printed prescriptions
approved_at	TIMESTAMPTZ	NULLABLE	When admin approved the account
approved_by	UUID	NULLABLE, FK profiles(id)	Admin who approved
suspended_reason	TEXT	NULLABLE	If suspended, reason recorded here
created_at	TIMESTAMPTZ	DEFAULT now()	Profile creation
updated_at	TIMESTAMPTZ	DEFAULT now()	Last update

Table name: doctor_clinic_affiliations (junction table)

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
clinic_id	UUID	NOT NULL, FK clinics(id)	
role_at_clinic	VARCHAR(50)	DEFAULT 'visiting', CHECK IN ('visiting','resident','head_of_department','consultant')	
start_date	DATE	NOT NULL	When affiliation started
end_date	DATE	NULLABLE	NULL means currently active
is_primary	BOOLEAN	DEFAULT false	Primary practice location
created_at	TIMESTAMPTZ	DEFAULT now()	
UNIQUE(doctor_id, clinic_id, start_date)			Prevent duplicate active affiliations

3.4 Lab Worker Extended Profile

Table name: lab_worker_profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, FK profiles(id)	Same ID as base profile
lab_id	UUID	NOT NULL, FK diagnostic_labs(id)	Which lab this worker belongs to
employee_id	VARCHAR(50)	NULLABLE	Internal employee ID at the lab
position_title	VARCHAR(100)	NULLABLE	e.g. Senior Lab Technician
can_upload_results	BOOLEAN	DEFAULT true	Permission to upload result files
can_mark_order_collected	BOOLEAN	DEFAULT true	Permission to mark sample as collected
can_mark_order_processing	BOOLEAN	DEFAULT true	Permission to mark as being processed
can_mark_order_resulted	BOOLEAN	DEFAULT true	Permission to mark as result uploaded
approved_at	TIMESTAMPZ	NULLABLE	When admin activated this account
approved_by	UUID	NULLABLE, FK profiles(id)	Admin who approved
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

3.5 Receptionist Extended Profile

Table name: receptionist_profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, FK profiles(id)	Same ID as base profile
clinic_id	UUID	NOT NULL, FK clinics(id)	Scoped to one clinic only
employee_id	VARCHAR(50)	NULLABLE	Internal employee ID
can_book_appointments	BOOLEAN	DEFAULT true	Book on behalf of walk-in patients
can_cancel_appointments	BOOLEAN	DEFAULT true	Cancel appointments
can_check_in_patients	BOOLEAN	DEFAULT true	Mark patient as arrived
can_print_health_card	BOOLEAN	DEFAULT true	Print or regenerate QR for patient
can_view_doctor_schedule	BOOLEAN	DEFAULT true	See the doctor's appointment list
approved_at	TIMESTAMPZ	NULLABLE	
approved_by	UUID	NULLABLE, FK profiles(id)	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

3.6 Admin Profile

Table name: admin_profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY, FK profiles(id)	Same ID as base profile
admin_level	VARCHAR(20)	NOT NULL, CHECK IN ('super_admin','regional_admin','support_admin')	Super admin has all powers
region_scope	VARCHAR(50)	NULLABLE	If regional admin, which province/region
can_approve_doctors	BOOLEAN	DEFAULT true	Approve or reject doctor registrations
can_approve_labs	BOOLEAN	DEFAULT true	Approve diagnostic labs
can_suspend_accounts	BOOLEAN	DEFAULT true	Suspend any non-admin account
can_view_audit_logs	BOOLEAN	DEFAULT true	Access to audit trail
can_export_reports	BOOLEAN	DEFAULT true	Run and download aggregate reports
can_manage_consent_templates	BOOLEAN	DEFAULT false	Only super admin by default
can_issue_qr_cards	BOOLEAN	DEFAULT true	Manually issue or regenerate QR
can_manage_system_config	BOOLEAN	DEFAULT false	Only super admin
employee_id	VARCHAR(50)	NULLABLE	Government/organization employee ID
department	VARCHAR(100)	NULLABLE	Health authority department name
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

3.7 Supporting Entities

Clinics

Table name: clinics

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
name	VARCHAR(255)	NOT NULL	Clinic or hospital name
type	VARCHAR(50)	CHECK IN ('clinic','hospital','polyclinic','teaching_hospital','rural_health_centre','basic_health_unit','dispensary')	Facility type
license_number	VARCHAR(100)	UNIQUE, NULLABLE	Government health facility license
phone	VARCHAR(15)	NULLABLE	Main contact number
email	VARCHAR(255)	NULLABLE	Main contact email
address_street	TEXT	NOT NULL	Street address
address_city	VARCHAR(100)	NOT NULL	City
address_province	VARCHAR(50)	NOT NULL	Province
address_postal_code	VARCHAR(10)	NULLABLE	

Field	Type	Constraints	Description
latitude	DECIMAL(9,6)	NULLABLE	GPS latitude for map view
longitude	DECIMAL(9,6)	NULLABLE	GPS longitude for map view
operating_hours	JSONB	NULLABLE	{"monday":{"open":"08:00","close":"18:00"},...}
status	VARCHAR(20)	DEFAULT 'active', CHECK IN ('active','suspended','closed')	
created_at	TIMESTAMPTZ	DEFAULT now()	
updated_at	TIMESTAMPTZ	DEFAULT now()	

Diagnostic Labs

Table name: diagnostic_labs

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
name	VARCHAR(255)	NOT NULL	Lab name
license_number	VARCHAR(100)	UNIQUE, NOT NULL	Health authority lab license
license_verified	BOOLEAN	DEFAULT false	Admin verified
license_verified_at	TIMESTAMPTZ	NULLABLE	
phone	VARCHAR(15)	NOT NULL	
email	VARCHAR(255)	NULLABLE	
address_street	TEXT	NOT NULL	
address_city	VARCHAR(100)	NOT NULL	
address_province	VARCHAR(50)	NOT NULL	
latitude	DECIMAL(9,6)	NULLABLE	
longitude	DECIMAL(9,6)	NULLABLE	
supported_tests	TEXT[]	NULLABLE	Array of LOINC codes for tests this lab offers
result_turnaround_hours	INTEGER	NULLABLE	Average hours from sample to result
status	VARCHAR(20)	DEFAULT 'pending', CHECK IN ('active','pending','suspended','closed')	
created_at	TIMESTAMPTZ	DEFAULT now()	
updated_at	TIMESTAMPTZ	DEFAULT now()	

SECTION 4: COMPLETE DATABASE SCHEMA

4.1 Scheduling Layer

doctor_availability

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
clinic_id	UUID	NULLABLE, FK clinics(id)	NULL means telehealth slot
slot_type	VARCHAR(20)	CHECK IN ('in_person','telehealth')	
recurrence	VARCHAR(20)	CHECK IN ('once','weekly','biweekly')	
day_of_week	SMALLINT	NULLABLE, CHECK 0-6	0=Sunday, 6=Saturday. NULL if recurrence='once'
specific_date	DATE	NULLABLE	Used when recurrence='once'
start_time	TIME	NOT NULL	
end_time	TIME	NOT NULL	
slot_duration_minutes	SMALLINT	NOT NULL, DEFAULT 15	
max_patients	SMALLINT	NULLABLE	Cap on bookings per slot window
is_active	BOOLEAN	DEFAULT true	Doctor can pause availability
created_at	TIMESTAMPTZ	DEFAULT now()	
updated_at	TIMESTAMPTZ	DEFAULT now()	

appointments

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
clinic_id	UUID	NULLABLE, FK clinics(id)	NULL for telehealth
availability_slot_id	UUID	NULLABLE, FK doctor_availability(id)	Which slot was booked
appointment_date	DATE	NOT NULL	
appointment_time	TIME	NOT NULL	
appointment_type	VARCHAR(20)	NOT NULL, CHECK IN ('in_person','telehealth','follow_up','emergency')	
status	VARCHAR(30)	NOT NULL, DEFAULT 'pending', CHECK IN ('pending','confirmed','checked_in','in_progress','completed','cancelled_by_patient','cancelled_by_doctor','no_show','rescheduled')	
booked_by_role	VARCHAR(20)	CHECK IN ('patient','receptionist','doctor')	Who created the booking
booked_by_id	UUID	NOT NULL, FK profiles(id)	The actual user who pressed Book
confirmed_at	TIMESTAMPTZ	NULLABLE	When doctor confirmed
checked_in_at	TIMESTAMPTZ	NULLABLE	When patient was marked arrived
completed_at	TIMESTAMPTZ	NULLABLE	When encounter was finalised
cancelled_at	TIMESTAMPTZ	NULLABLE	
cancellation_reason	TEXT	NULLABLE	
reminder_24h_sent	BOOLEAN	DEFAULT false	24-hour reminder sent flag
reminder_1h_sent	BOOLEAN	DEFAULT false	1-hour reminder sent flag
telehealth_room_url	TEXT	NULLABLE	Generated video call room URL

Field	Type	Constraints	Description
notes_for_doctor	TEXT	NULLABLE	Patient's reason for visit
encounter_id	UUID	NULLABLE, FK encounters(id)	Linked when doctor finalises
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

appointment_reviews

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
appointment_id	UUID	UNIQUE, NOT NULL, FK appointments(id)	One review per appointment
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
rating	SMALLINT	NOT NULL, CHECK 1-5	
review_text	TEXT	NULLABLE	Optional free text
is_anonymous	BOOLEAN	DEFAULT false	Hide patient name from public view
created_at	TIMESTAMPZ	DEFAULT now()	

4.2 Clinical Data Layer (FHIR-Mapped)

encounters

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR Encounter.id
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
appointment_id	UUID	NULLABLE, FK appointments(id)	NULL for walk-in or emergency
clinic_id	UUID	NULLABLE, FK clinics(id)	NULL for telehealth
encounter_type	VARCHAR(50)	NOT NULL, CHECK IN ('outpatient','inpatient','emergency','telehealth','follow_up','home_visit')	
encounter_date	DATE	NOT NULL	
encounter_time	TIME	NOT NULL	
chief_complaint	TEXT	NULLABLE	Patient's stated reason for visit
history_of_present_illness	TEXT	NULLABLE	Doctor's narrative of current issue
review_of_systems	JSONB	NULLABLE	Structured systems review
physical_examination_notes	TEXT	NULLABLE	Findings from physical exam
assessment	TEXT	NULLABLE	Doctor's overall clinical assessment
plan	TEXT	NULLABLE	Treatment plan narrative
follow_up_required	BOOLEAN	DEFAULT false	

Field	Type	Constraints	Description
follow_up_date	DATE	NULLABLE	Suggested follow-up date
follow_up_notes	TEXT	NULLABLE	Instructions for follow-up
status	VARCHAR(20)	NOT NULL, DEFAULT 'draft', CHECK IN ('draft','finalized','amended')	
finalized_at	TIMESTAMPZ	NULLABLE	When doctor submitted the encounter
amendment_of	UUID	NULLABLE, FK encounters(id)	Points to original if this is an amendment
amendment_reason	TEXT	NULLABLE	Why an amendment was needed
is_confidential	BOOLEAN	DEFAULT false	Marks entire encounter as sensitive
confidential_reason	VARCHAR(50)	NULLABLE, CHECK IN ('psychiatry','reproductive','substance','hiv','other')	
patient_visible	BOOLEAN	DEFAULT true	Doctor can hide specific notes from patient
fhir_resource_id	VARCHAR(255)	NULLABLE	ID on HAPI FHIR server if synced
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

conditions

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR Condition.id
encounter_id	UUID	NOT NULL, FK encounters(id)	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Denormalised for query performance
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	Author
icd10_code	VARCHAR(10)	NULLABLE	ICD-10 diagnosis code
snomed_code	VARCHAR(20)	NULLABLE	SNOMED CT code
condition_display	VARCHAR(500)	NOT NULL	Human-readable condition name
category	VARCHAR(50)	CHECK IN ('problem_list','encounter_diagnosis','health_concern')	
severity	VARCHAR(20)	NULLABLE, CHECK IN ('mild','moderate','severe','critical','unknown')	
onset_date	DATE	NULLABLE	When condition started
onset_is_estimated	BOOLEAN	DEFAULT false	If onset date is approximate
resolution_date	DATE	NULLABLE	When resolved, NULL if ongoing
clinical_status	VARCHAR(20)	NOT NULL, DEFAULT 'active', CHECK IN ('active','recurrence','relapse','inactive','remission','resolved')	
verification_status	VARCHAR(20)	NOT NULL, DEFAULT 'confirmed', CHECK IN ('unconfirmed','provisional','differential','confirmed','refuted')	
notes	TEXT	NULLABLE	Additional clinical notes
is_chronic	BOOLEAN	DEFAULT false	Marks as ongoing chronic condition
fhir_resource_id	VARCHAR(255)	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

medication_requests

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR MedicationRequest.id
encounter_id	UUID	NOT NULL, FK encounters(id)	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Denormalised
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	Prescribing doctor
medication_name	VARCHAR(255)	NOT NULL	Generic name
medication_brand	VARCHAR(255)	NULLABLE	Brand name if specified
medication_code	VARCHAR(50)	NULLABLE	ATC or local drug code
dosage_value	DECIMAL(8,3)	NOT NULL	Numeric dosage amount
dosage_unit	VARCHAR(20)	NOT NULL	mg, ml, units, etc
route	VARCHAR(50)	NOT NULL, CHECK IN ('oral','intravenous','intramuscular','subcutaneous','topical','inhaled','rectal','sublingual','nasal','ophthalmic','otic','other')	Route of administration
frequency	VARCHAR(50)	NOT NULL	e.g. twice_daily, every_8_hours
frequency_times_per_day	SMALLINT	NULLABLE	Numeric representation
duration_days	SMALLINT	NULLABLE	How many days to take
total_quantity	DECIMAL(8,2)	NULLABLE	Total amount to dispense
quantity_unit	VARCHAR(20)	NULLABLE	Tablets, ml, etc
refills_allowed	SMALLINT	DEFAULT 0	How many refills permitted
refills_used	SMALLINT	DEFAULT 0	Running count
instructions	TEXT	NULLABLE	Patient instructions (take with food, etc)
indication	TEXT	NULLABLE	What this is being prescribed for
start_date	DATE	NULLABLE	When to start taking
end_date	DATE	NULLABLE	When to stop (computed from duration)
status	VARCHAR(30)	NOT NULL, DEFAULT 'active', CHECK IN ('active','on_hold','cancelled','completed','entered_in_error','stopped','draft')	
substitution_allowed	BOOLEAN	DEFAULT true	Generic substitution permitted
requires_prior_auth	BOOLEAN	DEFAULT false	Insurance prior auth needed
is_controlled_substance	BOOLEAN	DEFAULT false	Flagged for controlled medications
fhir_resource_id	VARCHAR(255)	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

medication_refill_requests

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
original_medication_request_id	UUID	NOT NULL, FK medication_requests(id)	Which prescription this refills

Field	Type	Constraints	Description
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	Doctor who originally prescribed
requested_at	TIMESTAMPZ	DEFAULT now()	
patient_notes	TEXT	NULLABLE	Why they need a refill
status	VARCHAR(20)	DEFAULT 'pending', CHECK IN ('pending','approved','denied','cancelled')	
reviewed_at	TIMESTAMPZ	NULLABLE	When doctor responded
doctor_notes	TEXT	NULLABLE	Doctor's reason for denial or instructions
resulting_medication_request_id	UUID	NULLABLE, FK medication_requests(id)	New prescription if approved

observations

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR Observation.id
encounter_id	UUID	NULLABLE, FK encounters(id)	NULL if standalone lab observation
lab_result_id	UUID	NULLABLE, FK lab_results(id)	Populated when observation comes from lab
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Denormalised
authored_by_id	UUID	NOT NULL, FK profiles(id)	Doctor or lab worker
authored_by_role	VARCHAR(20)	NOT NULL, CHECK IN ('doctor','lab_worker')	
loinc_code	VARCHAR(20)	NULLABLE	LOINC code for the observation type
snomed_code	VARCHAR(20)	NULLABLE	
observation_display	VARCHAR(255)	NOT NULL	Human-readable name (e.g. Fasting Blood Glucose)
category	VARCHAR(50)	CHECK IN ('vital_signs','laboratory','imaging','procedure','social_history','activity','exam','survey','therapy')	
value_quantity	DECIMAL(12,4)	NULLABLE	Numeric result
value_unit	VARCHAR(50)	NULLABLE	Unit of measure
value_string	TEXT	NULLABLE	For text results
value_boolean	BOOLEAN	NULLABLE	For yes/no results
value_code	VARCHAR(50)	NULLABLE	For coded results
reference_range_low	DECIMAL(12,4)	NULLABLE	Normal range lower bound
reference_range_high	DECIMAL(12,4)	NULLABLE	Normal range upper bound
reference_range_text	VARCHAR(255)	NULLABLE	Text description of normal range
interpretation	VARCHAR(20)	NULLABLE, CHECK IN ('normal','high','low','critical_high','critical_low','abnormal','resistant','susceptible','indeterminate')	
observation_date	DATE	NOT NULL	
observation_time	TIME	NULLABLE	
status	VARCHAR(20)	NOT NULL, DEFAULT 'final', CHECK IN ('registered','preliminary','final','amended','corrected','cancelled','entered_in_error')	

Field	Type	Constraints	Description
notes	TEXT	NULLABLE	
patient_visible	BOOLEAN	DEFAULT true	Doctor can hold back
fhir_resource_id	VARCHAR(255)	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

allergies

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR AllergyIntolerance.id
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
recorded_by_id	UUID	NOT NULL, FK profiles(id)	Doctor or patient themselves
recorded_by_role	VARCHAR(20)	CHECK IN ('doctor','patient')	
encounter_id	UUID	NULLABLE, FK encounters(id)	If recorded during encounter
substance_name	VARCHAR(255)	NOT NULL	Allergen name
substance_code	VARCHAR(50)	NULLABLE	SNOMED or drug code
allergy_type	VARCHAR(20)	CHECK IN ('allergy','intolerance','unknown')	
category	VARCHAR(20)	CHECK IN ('food','medication','environment','biologic','other')	
criticality	VARCHAR(20)	CHECK IN ('low','high','unable_to_assess')	
reaction_description	TEXT	NULLABLE	What happens when exposed
onset_date	DATE	NULLABLE	
clinical_status	VARCHAR(20)	DEFAULT 'active', CHECK IN ('active','inactive','resolved')	
verification_status	VARCHAR(20)	DEFAULT 'confirmed', CHECK IN ('unconfirmed','confirmed','refuted','entered_in_error')	
fhir_resource_id	VARCHAR(255)	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

4.3 Lab Workflow Layer

lab_orders

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
encounter_id	UUID	NOT NULL, FK encounters(id)	Created within an encounter
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Denormalised
ordering_doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	Who ordered the test

Field	Type	Constraints	Description
lab_id	UUID	NOT NULL, FK diagnostic_labs(id)	Which lab to send to
lab_order_number	VARCHAR(50)	UNIQUE, NOT NULL	Auto-generated order number e.g. LO-2024-000123
test_name	VARCHAR(255)	NOT NULL	Human readable test name
loinc_code	VARCHAR(20)	NULLABLE	LOINC code for the test
test_panel	VARCHAR(100)	NULLABLE	Panel name if part of a group (e.g. Complete Blood Count)
priority	VARCHAR(20)	NOT NULL, DEFAULT 'routine', CHECK IN ('routine','urgent','stat')	
clinical_indication	TEXT	NULLABLE	Why this test was ordered
special_instructions	TEXT	NULLABLE	Fasting required, etc
specimen_type	VARCHAR(50)	NULLABLE	Blood, urine, stool, swab, etc
status	VARCHAR(30)	NOT NULL, DEFAULT 'ordered', CHECK IN ('ordered','sample_collected','processing','resulted','reviewed','released_to_patient','cancelled')	
ordered_at	TIMESTAMPZ	DEFAULT now()	
sample_collected_at	TIMESTAMPZ	NULLABLE	Lab marks this
sample_collected_by	UUID	NULLABLE, FK lab_worker_profiles(id)	
processing_started_at	TIMESTAMPZ	NULLABLE	
resulted_at	TIMESTAMPZ	NULLABLE	When lab uploads result
reviewed_at	TIMESTAMPZ	NULLABLE	When doctor marks reviewed
reviewed_by	UUID	NULLABLE, FK doctor_profiles(id)	May differ from ordering doctor
released_to_patient_at	TIMESTAMPZ	NULLABLE	When patient can see it
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

lab_results

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
lab_order_id	UUID	UNIQUE, NOT NULL, FK lab_orders(id)	One result per order
lab_id	UUID	NOT NULL, FK diagnostic_labs(id)	
uploaded_by	UUID	NOT NULL, FK lab_worker_profiles(id)	Which worker uploaded
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Denormalised
result_file_url	TEXT	NULLABLE	URL to PDF in secure storage
result_file_name	VARCHAR(255)	NULLABLE	Original file name
result_file_size_bytes	INTEGER	NULLABLE	File size
result_file_hash	VARCHAR(64)	NULLABLE	SHA-256 of file for integrity check
structured_results	JSONB	NULLABLE	Key-value pairs: [{"name":"Haemoglobin","value":14.2,"unit":"g/dL","flag":"normal"},...]
lab_technician_name	VARCHAR(255)	NULLABLE	Name of technician who ran the test
lab_machine_id	VARCHAR(100)	NULLABLE	Equipment used

Field	Type	Constraints	Description
comments	TEXT	NULLABLE	Lab's comments on the result
is_critical_value	BOOLEAN	DEFAULT false	Flagged if result is in critical range
critical_value_notified	BOOLEAN	DEFAULT false	Whether doctor was called for critical value
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

4.4 Documents Layer

documents

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	Who this document belongs to
encounter_id	UUID	NULLABLE, FK encounters(id)	If attached to a specific encounter
uploaded_by_id	UUID	NOT NULL, FK profiles(id)	Who uploaded it
uploaded_by_role	VARCHAR(20)	CHECK IN ('doctor','patient','lab_worker','receptionist')	
document_type	VARCHAR(50)	NOT NULL, CHECK IN ('referral_letter','discharge_summary','imaging_report','prescription_printout','consent_form','insurance_document','vaccination_record','previous_record','other')	
document_title	VARCHAR(255)	NOT NULL	
description	TEXT	NULLABLE	
file_url	TEXT	NOT NULL	URL in secure storage
file_name	VARCHAR(255)	NOT NULL	
file_size_bytes	INTEGER	NOT NULL	
file_type	VARCHAR(50)	NOT NULL	MIME type: application/pdf, image/jpeg, etc
file_hash	VARCHAR(64)	NOT NULL	SHA-256 integrity check
patient_visible	BOOLEAN	DEFAULT true	Doctor can mark a document as internal only
is_confidential	BOOLEAN	DEFAULT false	
created_at	TIMESTAMPZ	DEFAULT now()	
updated_at	TIMESTAMPZ	DEFAULT now()	

4.5 Communication Layer

message_threads

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	

Field	Type	Constraints	Description
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
doctor_id	UUID	NOT NULL, FK doctor_profiles(id)	
subject	VARCHAR(255)	NULLABLE	Thread subject/topic
status	VARCHAR(20)	DEFAULT 'open', CHECK IN ('open','closed','archived')	
last_message_at	TIMESTAMPZ	NULLABLE	Updated on each new message (for sorting)
last_message_preview	VARCHAR(100)	NULLABLE	First 100 chars of last message, for list view
patient_unread_count	INTEGER	DEFAULT 0	Unread messages for patient
doctor_unread_count	INTEGER	DEFAULT 0	Unread messages for doctor
created_at	TIMESTAMPZ	DEFAULT now()	
UNIQUE(patient_id, doctor_id)			One thread per patient-doctor pair

messages

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Maps to FHIR Communication.id
thread_id	UUID	NOT NULL, FK message_threads(id)	
sender_id	UUID	NOT NULL, FK profiles(id)	
sender_role	VARCHAR(20)	NOT NULL, CHECK IN ('patient','doctor')	
body_encrypted	TEXT	NOT NULL	AES-256 encrypted message body
body_iv	VARCHAR(32)	NOT NULL	Initialisation vector for decryption
message_type	VARCHAR(20)	DEFAULT 'text', CHECK IN ('text','refill_request','appointment_request','question','follow_up','system')	
attachment_url	TEXT	NULLABLE	File attachment if any
attachment_name	VARCHAR(255)	NULLABLE	
attachment_type	VARCHAR(50)	NULLABLE	MIME type
attachment_size_bytes	INTEGER	NULLABLE	
sent_at	TIMESTAMPZ	DEFAULT now()	
delivered_at	TIMESTAMPZ	NULLABLE	When received by server (always near instant)
read_at	TIMESTAMPZ	NULLABLE	When recipient opened it
is_deleted_by_sender	BOOLEAN	DEFAULT false	Soft delete for sender view
is_deleted_by_recipient	BOOLEAN	DEFAULT false	Soft delete for recipient view
idempotency_key	UUID	UNIQUE, NOT NULL	Prevents duplicate sends on retry
fhir_resource_id	VARCHAR(255)	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	

4.6 Audit and Compliance Layer

audit_logs

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
actor_id	UUID	NULLABLE, FK profiles(id)	NULL for system actions
actor_role	VARCHAR(20)	NULLABLE	Role at time of action
action	VARCHAR(50)	NOT NULL	CREATE, READ, UPDATE, DELETE, LOGIN, LOGOUT, etc
resource_type	VARCHAR(50)	NOT NULL	Table/entity name
resource_id	UUID	NULLABLE	ID of the affected record
patient_id	UUID	NULLABLE	If action involves a patient record
ip_address	INET	NULLABLE	Client IP
device_fingerprint	TEXT	NULLABLE	Device identifier
user_agent	TEXT	NULLABLE	Browser or app user agent string
request_id	UUID	NULLABLE	Trace ID for the HTTP request
changes	JSONB	NULLABLE	Before/after values for UPDATE actions
status	VARCHAR(20)	NOT NULL, CHECK IN ('success','failure','partial')	
failure_reason	TEXT	NULLABLE	If status=failure
timestamp	TIMESTAMPTZ	NOT NULL, DEFAULT now()	
NOTE: No UPDATE or DELETE policy on this table ever			Append only, enforced by RLS

consent_records

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	
consent_type	VARCHAR(50)	NOT NULL, CHECK IN ('data_processing','data_sharing','research_use','marketing','third_party_access')	
consent_version	VARCHAR(10)	NOT NULL	e.g. v1.2
action	VARCHAR(10)	NOT NULL, CHECK IN ('granted','revoked','updated')	
granted_at	TIMESTAMPTZ	NULLABLE	
revoked_at	TIMESTAMPTZ	NULLABLE	
ip_address	INET	NULLABLE	
created_at	TIMESTAMPTZ	DEFAULT now()	

qr_tokens

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
patient_id	UUID	NOT NULL, FK patient_profiles(id)	

Field	Type	Constraints	Description
token	UUID	UNIQUE, NOT NULL	The token encoded in the QR code
issued_at	TIMESTAMPZ	DEFAULT now()	
issued_by	UUID	NULLABLE, FK profiles(id)	System or admin who issued it
invalidated	BOOLEAN	DEFAULT false	
invalidated_at	TIMESTAMPZ	NULLABLE	
invalidated_reason	VARCHAR(50)	NULLABLE, CHECK IN ('lost','stolen','expired','replaced','admin_action')	
is_current	BOOLEAN	DEFAULT true	Only one can be current per patient

notifications

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	
recipient_id	UUID	NOT NULL, FK profiles(id)	
notification_type	VARCHAR(50)	NOT NULL	appointment_reminder, new_message, lab_ready, etc
channel	VARCHAR(20)	NOT NULL, CHECK IN ('push','sms','email','in_app')	
generic_title	VARCHAR(100)	NOT NULL	Safe title, never reveals clinical info
generic_body	VARCHAR(255)	NOT NULL	Safe body, never reveals clinical info
deep_link	VARCHAR(255)	NULLABLE	Where to navigate in app on tap
reference_id	UUID	NULLABLE	ID of related entity (appointment, message, etc)
sent_at	TIMESTAMPZ	NULLABLE	When dispatched
delivered_at	TIMESTAMPZ	NULLABLE	When confirmed delivered
read_at	TIMESTAMPZ	NULLABLE	When user opened it
failed	BOOLEAN	DEFAULT false	If delivery failed
failure_reason	TEXT	NULLABLE	
created_at	TIMESTAMPZ	DEFAULT now()	

SECTION 5: FUNCTIONAL REQUIREMENTS

5.1 Registration and Identity

FR-001: The system shall allow any person with a valid 13-digit CNIC to register as a patient without requiring human approval.

FR-002: The system shall verify a submitted CNIC against the NADRA API before completing patient registration.

FR-003: The system shall send an OTP to the patient's submitted phone number and require correct entry within 5 minutes to complete registration.

FR-004: The system shall create a unique QR-coded health card for every patient immediately upon successful registration.

FR-005: The QR code shall encode an opaque token (UUID), not the raw CNIC.

FR-006: The system shall allow a patient to regenerate their QR token if they report their card as lost or stolen, automatically invalidating the previous token.

FR-007: The system shall require doctors to submit their PMDC number, CNIC, primary qualifications, and at least one clinic affiliation during registration.

FR-008: Doctor accounts shall be created in PENDING status and shall not allow login until an admin approves them.

FR-009: The system shall notify the applicant doctor via SMS and push notification when their account status changes.

FR-010: The system shall require admin approval for diagnostic lab registrations, including verification of the lab's government license number.

FR-011: The system shall allow admins to create receptionist accounts, scoped to a specific clinic.

FR-012: The system shall allow admins to create lab worker accounts, scoped to a specific diagnostic lab.

FR-013: The system shall enforce CNIC uniqueness across all user types — the same CNIC cannot be used for two accounts of any role.

FR-014: The system shall allow a user to change their password after verifying their identity via OTP.

FR-015: The system shall lock an account for 30 minutes after 5 consecutive failed login attempts.

FR-016: The system shall log every login attempt (success or failure) with timestamp, IP, and device fingerprint.

FR-017: The system shall support MFA for all roles, mandatory for doctors.

FR-018: The system shall support biometric authentication on supported devices as an MFA option.

FR-019: The system shall store the CNIC as a hashed value for lookup, with only the last 4 digits shown in any UI.

FR-020: The system shall assign every patient a human-readable health card number (format: HC-YYYY-XXXXXXX) in addition to the QR token.

5.2 Patient Features

FR-021: A patient shall be able to view their complete health timeline in reverse chronological order.

FR-022: The health timeline shall include encounters, diagnoses, medications, lab results, and uploaded documents.

FR-023: A patient shall be able to filter their timeline by date range, record type, and treating doctor.

FR-024: A patient shall be able to search their timeline by keyword.

FR-025: A patient shall be able to view the details of any encounter on their timeline.

FR-026: A patient shall be able to download a PDF copy of any prescription or lab result.

FR-027: A patient shall be able to set privacy flags to hide specific categories of encounters (psychiatry, reproductive health, substance use) from the default doctor view.

FR-028: A patient shall be able to grant a specific doctor temporary access to hidden encounter categories during a consultation.

FR-029: A patient shall be able to view and update their personal demographic information (contact details, address, emergency contact).

FR-030: A patient shall be able to update their blood group, known allergies, and height/weight.

FR-031: A patient shall be able to search for registered doctors by name, specialization, clinic, and city.

FR-032: A patient shall be able to view a doctor's public profile including qualifications, rating, consultation fee, and available slots.

FR-033: A patient shall be able to book an appointment with a doctor by selecting an available slot.

FR-034: A patient shall be able to cancel an appointment up to 2 hours before the scheduled time.

FR-035: A patient shall be able to reschedule an appointment to a different available slot.

FR-036: A patient shall be able to view their upcoming and past appointments.

FR-037: A patient shall be able to rate and review a doctor after a completed appointment.

- FR-038: A patient shall receive SMS and push notification reminders 24 hours and 1 hour before an appointment.
- FR-039: A patient shall be able to initiate a secure message to any doctor they have had an appointment with.
- FR-040: A patient shall be able to attach a file (photo or PDF, max 10MB) to a message.
- FR-041: A patient shall be able to request a medication refill for any active prescription with remaining refills.
- FR-042: A patient shall be notified when a doctor responds to their refill request.
- FR-043: A patient shall be able to view their active insurance details and update policy information.
- FR-044: A patient shall receive a push notification when a new lab result is released to them by the doctor.
- FR-045: A patient shall receive a medication renewal reminder 7 days and 3 days before an active prescription expires.
- FR-046: A patient shall be able to view their allergy list separately from the main timeline.
- FR-047: A patient shall be able to grant or revoke consent for data processing at any time from settings.
- FR-048: A patient shall be able to request deletion of their account, with data retained for the legally required period.
- FR-049: A patient shall be able to change their notification preferences independently for push, SMS, and email.
- FR-050: A patient shall be able to display their health card QR code directly from the app's home screen without additional navigation.
- FR-051: A patient shall be able to view a consolidated medication list showing all currently active prescriptions.
- FR-052: A patient shall be able to add a note to their profile (visible only to themselves) about a specific encounter or medication.
- FR-053: A patient shall be able to share a specific document with a new doctor by generating a time-limited share link.
- FR-054: A patient shall be able to switch the app language between English and Urdu.
- FR-055: A patient shall be able to nominate an emergency access contact who can present the health card on behalf of the patient.

5.3 Doctor Features

- FR-056: A doctor shall be able to search for a patient by scanning their QR code.
- FR-057: A doctor shall be able to search for a patient by entering their CNIC number manually.
- FR-058: A doctor shall be able to search for a patient by their health card number.
- FR-059: A doctor shall be able to view a patient's full health timeline after accessing their record.
- FR-060: A doctor shall be able to create a new encounter for a patient.
- FR-061: A doctor shall be able to record the chief complaint, history of present illness, physical examination findings, and clinical assessment within an encounter.
- FR-062: A doctor shall be able to add one or more ICD-10 coded diagnoses to an encounter.
- FR-063: A doctor shall be able to add one or more SNOMED CT coded observations to an encounter.
- FR-064: A doctor shall be able to prescribe medications within an encounter, specifying drug name, dosage, route, frequency, and duration.
- FR-065: A doctor shall be able to mark a prescription as a controlled substance.
- FR-066: A doctor shall be able to attach documents to an encounter (referral letters, imaging reports, etc).
- FR-067: A doctor shall be able to create a lab order within an encounter, selecting a test from a searchable list of available tests and a specific diagnostic lab.
- FR-068: A doctor shall be able to finalize an encounter, after which the clinical data becomes immutable.
- FR-069: A doctor shall be able to create an amendment to a finalized encounter, with a mandatory reason, rather than editing the original.
- FR-070: A doctor shall be able to mark specific encounter notes as confidential so they are not visible to the patient.
- FR-071: A doctor shall be able to set a follow-up date and instructions at the end of an encounter.

- FR-072: A doctor shall be notified when a lab result is uploaded for a patient they ordered a test for.
- FR-073: A doctor shall be able to review a lab result and release it to the patient.
- FR-074: A doctor shall be able to manage their availability calendar by adding, editing, and removing time slots.
- FR-075: A doctor shall be able to set different availability for in-person and telehealth appointments.
- FR-076: A doctor shall be able to view their appointment list for the day, week, and month.
- FR-077: A doctor shall be able to confirm or cancel pending appointment requests.
- FR-078: A doctor shall be able to mark a patient as checked in.
- FR-079: A doctor shall be able to mark an appointment as a no-show.
- FR-080: A doctor shall be able to view and respond to messages from their patients.
- FR-081: A doctor shall be able to approve or deny medication refill requests from patients.
- FR-082: A doctor shall be able to view aggregate statistics about their patients (appointment counts, common diagnoses, etc) without seeing other doctors' data.
- FR-083: A doctor shall be able to generate and print a prescription PDF with their digital signature.
- FR-084: A doctor shall be able to update their public profile, including bio, qualifications, and consultation fee.
- FR-085: A doctor shall be able to add or remove clinic affiliations.
- FR-086: A doctor shall be able to record a patient's allergy and mark it as confirmed.
- FR-087: A doctor shall be able to view all active medications across all a patient's encounters on a single consolidated view.
- FR-088: A doctor shall receive a prominent warning if they try to prescribe a medication the patient is allergic to.
- FR-089: A doctor shall be able to initiate a telehealth video session for a confirmed telehealth appointment.
- FR-090: A doctor shall be able to add vitals (blood pressure, pulse, temperature, oxygen saturation, respiratory rate, weight) to an encounter with a single structured form.

5.4 Lab Worker Features

- FR-091: A lab worker shall see only the lab orders addressed to their specific lab.
- FR-092: A lab worker shall be able to view the queue of pending lab orders sorted by priority (STAT first, then urgent, then routine).
- FR-093: A lab worker shall be able to mark a lab order as sample collected, recording the timestamp.
- FR-094: A lab worker shall be able to mark a lab order as processing.
- FR-095: A lab worker shall be able to upload a result PDF against a lab order.
- FR-096: A lab worker shall be able to enter structured result values (name, value, unit, interpretation) in addition to or instead of a PDF upload.
- FR-097: A lab worker shall be able to flag a result as containing a critical value.
- FR-098: A lab worker shall mark a lab order as resulted after uploading, which triggers a notification to the ordering doctor.
- FR-099: A lab worker shall not be able to view any other part of a patient's health record beyond what is needed to process the lab order (patient name and order details only).
- FR-100: A lab worker shall not be able to view other patients' orders that belong to different labs.

5.5 Receptionist Features

- FR-101: A receptionist shall be able to search for a patient by CNIC or health card number.
- FR-102: A receptionist shall be able to book an appointment on behalf of a walk-in patient.
- FR-103: A receptionist shall be able to view and manage the appointment schedule for all doctors at their clinic.

FR-104: A receptionist shall be able to cancel an appointment on behalf of a patient.

FR-105: A receptionist shall be able to mark a patient as checked in.

FR-106: A receptionist shall be able to print a patient's health card QR code.

FR-107: A receptionist shall not be able to view clinical records, only demographic information needed for scheduling.

FR-108: A receptionist shall be able to register a new patient on their behalf (walk-in with no smartphone).

5.6 Admin Features

FR-109: An admin shall be able to view all pending doctor registration applications in a queue.

FR-110: An admin shall be able to review a doctor's submitted documents and approve or reject the application with a reason.

FR-111: An admin shall be able to view all pending lab registration applications.

FR-112: An admin shall be able to approve or reject a lab registration.

FR-113: An admin shall be able to suspend any non-admin account with a mandatory reason.

FR-114: An admin shall be able to reactivate a suspended account.

FR-115: An admin shall be able to issue or regenerate a patient's QR health card.

FR-116: An admin shall be able to create and manage clinic records.

FR-117: An admin shall be able to view aggregate system reports: total enrollments, daily active users, appointments per day, most common diagnoses, lab order volumes.

FR-118: An admin shall be able to export reports in CSV and PDF format.

FR-119: An admin shall be able to view the audit log for any user or resource.

FR-120: An admin shall be able to search the audit log by actor, resource type, date range, and action.

FR-121: An admin shall be able to manage consent policy templates and publish new versions.

FR-122: An admin shall be able to configure system settings including OTP expiry, account lockout thresholds, and session timeout durations.

FR-123: A super admin shall be able to create other admin accounts.

FR-124: An admin shall receive an email alert when a new doctor or lab registration application is submitted.

FR-125: An admin shall be able to view a doctor's complete registration details including PMDC number and uploaded credentials.

5.7 System-Level Functional Requirements

FR-126: The system shall prevent a doctor from being booked for two appointments at the same time slot.

FR-127: The system shall send appointment reminder notifications at exactly 24 hours and 1 hour before the appointment time.

FR-128: The system shall send medication renewal reminders 7 days and 3 days before a prescription end date.

FR-129: The system shall automatically close a message thread that has had no activity for 90 days.

FR-130: The system shall generate a unique, sequential lab order number in the format LO-YYYY-NNNNNN for every new lab order.

FR-131: The system shall generate a unique, sequential health card number in the format HC-YYYY-NNNNNNNN for every new patient.

FR-132: The system shall cache CNIC verification results from NADRA for 24 hours to avoid repeated API calls.

FR-133: The system shall support offline read access for patients and doctors, caching the last fetched state in local encrypted storage.

FR-134: The system shall queue write operations that fail due to offline state and retry them automatically when connectivity is restored.

FR-135: The system shall detect duplicate message sends using the `idempotency_key` field and return the existing message rather than creating a duplicate.

FR-136: The system shall log all failed payment or storage operations and alert the operations team.

FR-137: The system shall support Urdu language across all patient and doctor-facing screens.

FR-138: The system shall support right-to-left (RTL) text layout when Urdu is selected.

FR-139: The system shall enforce a maximum file upload size of 25MB per document.

FR-140: The system shall scan uploaded files for malware before storing them.

SECTION 6: NON-FUNCTIONAL REQUIREMENTS

6.1 Security

NFR-001: All data in transit shall be encrypted using TLS 1.3 minimum. TLS 1.0 and 1.1 connections shall be rejected.

NFR-002: All data at rest in the database shall be encrypted using AES-256.

NFR-003: All files in object storage shall be encrypted using AES-256 server-side encryption.

NFR-004: JWT access tokens shall expire after 60 minutes. Refresh tokens shall expire after 7 days.

NFR-005: A new refresh token shall be issued on every token refresh (token rotation), invalidating the previous refresh token.

NFR-006: The CNIC field shall be stored as a salted bcrypt hash in the auth layer. A separate HMAC-based lookup index enables search without storing plaintext.

NFR-007: Message bodies shall be encrypted at the application layer (AES-256-GCM) before storage, with keys managed in a hardware security module (HSM) or KMS.

NFR-008: QR token scan events shall be logged with the scanning doctor's ID, patient ID, and timestamp.

NFR-009: All API endpoints shall require a valid JWT Bearer token. No endpoint shall be publicly accessible except registration and login.

NFR-010: The system shall implement rate limiting: 10 OTP requests per phone number per hour, 100 API calls per user per minute, 5 failed login attempts before lockout.

NFR-011: All OTP codes shall be 6 digits, expire in 5 minutes, and be single-use.

NFR-012: Session timeout shall occur after 15 minutes of inactivity for doctors. Patients get 30 minutes.

NFR-013: The admin web portal shall enforce IP allowlisting — only approved IP ranges can access it.

NFR-014: The system shall implement RBAC where permissions are evaluated server-side on every request, never trusting client-supplied role claims.

NFR-015: Prescription PDFs shall carry the doctor's digital signature and a system-generated verification hash, detectable as tampered if modified.

NFR-016: The audit log table shall have no DELETE or UPDATE privilege granted to any database role including the application service account.

NFR-017: All cryptographic keys shall be rotated every 90 days. Old keys are retained in escrow for decrypting old data.

NFR-018: Penetration testing shall be conducted quarterly by an external security firm.

NFR-019: Dependency vulnerability scanning shall run on every CI/CD pipeline build.

NFR-020: Notification content shall never include clinical details, diagnosis names, medication names, or appointment types. Generic text only.

6.2 Performance

NFR-021: The patient health timeline API shall return the first page of results (20 items) in under 2 seconds for a patient with up to 10 years of records.

NFR-022: Patient search by CNIC for the doctor app shall return results in under 1 second.

NFR-023: Doctor's daily appointment list shall load in under 1 second.

NFR-024: Lab order queue for a lab worker shall load in under 1 second.

NFR-025: File uploads shall support resumable chunked upload for files over 5MB.

NFR-026: The QR code scan to patient record load shall complete in under 2 seconds on a 4G connection.

NFR-027: The system shall support 10,000 concurrent active users in initial deployment.

NFR-028: The system shall be designed to scale to 1,000,000 registered patients without schema changes.

NFR-029: Background jobs (reminders, notifications) shall be processed within 60 seconds of their scheduled time.

NFR-030: Database query plan analysis shall be conducted monthly and slow queries (>500ms) shall be optimised.

6.3 Availability and Reliability

NFR-031: System availability target is 99.9% (less than 8.7 hours downtime per year).

NFR-032: Scheduled maintenance windows shall occur between 02:00 and 05:00 PKT on Sundays.

NFR-033: The FHIR server shall run with at least 2 instances for redundancy.

NFR-034: The database shall have automated daily backups retained for 30 days.

NFR-035: Point-in-time recovery (PITR) shall be enabled with a 7-day recovery window.

NFR-036: A disaster recovery plan shall define an RTO (Recovery Time Objective) of 4 hours and RPO (Recovery Point Objective) of 1 hour.

NFR-037: The system shall implement circuit breakers on all external API calls (NADRA, SMS gateway) to degrade gracefully when those services are unavailable.

6.4 Compliance and Privacy

NFR-038: The system shall comply with Pakistan's Personal Data Protection Bill (PDPB) 2023.

NFR-039: Health data and CNIC numbers shall be classified as Sensitive Personal Data under PDPB, requiring highest protection tier.

NFR-040: Data residency: all PII and health data shall be stored on servers physically in Pakistan or the nearest compliant jurisdiction until a Pakistani data center is available.

NFR-041: The system shall implement the patient's right to erasure — account deactivation shall anonymize PII while retaining clinical records for the statutory period (10 years for medical records under Pakistani law).

NFR-042: The system shall maintain a data processing register documenting what data is collected, why, and how long it is retained.

NFR-043: Breach notification shall be implemented: if a data breach is detected, the admin team shall be alerted within 1 hour and affected patients within 72 hours per PDPB requirements.

NFR-044: The consent management system shall record versioned consent with timestamps, forming a legal audit trail.

NFR-045: Research data use shall only be permitted with explicit patient opt-in consent and shall use anonymized, aggregated data only.

NFR-046: Third-party vendors (SMS gateway, cloud storage) shall sign data processing agreements meeting PDPB standards before integration.

6.5 Usability and Accessibility

- NFR-047: The patient app shall comply with WCAG 2.1 Level AA accessibility guidelines.
- NFR-048: The minimum font size in the mobile apps shall be 14sp, with support for OS-level font scaling.
- NFR-049: All interactive elements shall have a minimum touch target size of 48x48dp.
- NFR-050: The app shall support the device's dark mode setting.
- NFR-051: All images that convey information shall have descriptive alt text for screen readers.
- NFR-052: The onboarding flow for a new patient shall be completable in under 3 minutes.
- NFR-053: Error messages shall describe what went wrong and what the user should do, never just an error code.
- NFR-054: The app shall function in areas with 2G connectivity for core read operations (cached data).

6.6 Interoperability

- NFR-055: All clinical data shall be storable and retrievable as HL7 FHIR R4 resources.
- NFR-056: The FHIR server shall expose a standard FHIR REST API for integration with external hospital EHR systems.
- NFR-057: ICD-10 codes shall be used for diagnoses, LOINC codes for observations and lab tests, SNOMED CT for clinical findings.
- NFR-058: The system shall provide a FHIR Subscription mechanism to notify external systems of new clinical data in real time.
- NFR-059: Export of a patient's complete health record shall be available in FHIR JSON bundle format.
- NFR-060: The system shall support HL7 v2 ADT messages from hospital systems as an alternative registration method.

SECTION 7: USER USE CASES

7.1 Patient Use Cases

UC-P001: Register as a new patient

Actor: Unregistered person

Precondition: Has a valid CNIC and Pakistani phone number

Steps: Open app, select Register as Patient, enter CNIC, enter name, enter phone, receive OTP, enter OTP, set password, confirm password, accept terms and consent, receive health card QR on home screen

Postcondition: Profile created, QR token issued, health card number assigned, confirmation SMS sent

UC-P002: Login to patient account

Actor: Registered patient

Precondition: Has active account

Steps: Open app, enter CNIC, enter password, receive OTP, enter OTP, land on home screen

Postcondition: Session established, last_login_at updated, audit log entry created

UC-P003: View health timeline

Actor: Logged-in patient

Steps: Navigate to Timeline tab, see list of encounters in reverse chronological order, each showing date, doctor name, clinic, and primary diagnosis, tap any entry to see full details

Postcondition: Audit log entry for READ on encounter resources

UC-P004: View a specific encounter

Actor: Logged-in patient

Steps: Tap an encounter from the timeline, view chief complaint, diagnoses with ICD-10 codes, medications prescribed with dosages, observations recorded, attached documents, doctor's notes (if patient-visible), follow-up date if set

Postcondition: Detailed encounter view displayed

UC-P005: View active prescriptions

Actor: Logged-in patient

Steps: Navigate to Medications tab, see all currently active MedicationRequest records across all encounters, each showing drug name, dosage, frequency, end date, and remaining refills

UC-P006: Request a prescription refill

Actor: Logged-in patient with an active prescription that has refills remaining

Steps: Go to Medications tab, select the prescription, tap Request Refill, enter optional note to doctor, submit

Postcondition: Refill request created with status pending, doctor receives notification

UC-P007: View lab results

Actor: Logged-in patient

Steps: Navigate to Labs tab, see list of lab orders, those released to patient show results, tap to view structured values and download the PDF report

UC-P008: Book an appointment

Actor: Logged-in patient

Steps: Search for a doctor by name or specialization, view doctor profile, tap Book Appointment, select appointment type (in-person or telehealth), browse available dates and time slots, select preferred slot, add note for doctor (reason for visit), confirm booking

Postcondition: Appointment created with status pending, doctor receives notification

UC-P009: Cancel an appointment

Actor: Logged-in patient

Precondition: Appointment is at least 2 hours away

Steps: Go to Appointments tab, find the appointment, tap Cancel, confirm cancellation, optionally provide reason

Postcondition: Appointment status changed to cancelled_by_patient, doctor notified

UC-P010: Reschedule an appointment

Actor: Logged-in patient

Steps: Go to Appointments, select appointment, tap Reschedule, pick new slot, confirm

Postcondition: Original appointment cancelled, new appointment created, doctor notified

UC-P011: Rate and review a doctor

Actor: Logged-in patient, appointment in completed status

Steps: Go to Appointments, find completed appointment, tap Leave Review, select star rating 1-5, optionally write review text, choose if anonymous, submit

Postcondition: Review saved, doctor average_rating updated via database trigger

UC-P012: Send a message to a doctor

Actor: Logged-in patient who has had at least one appointment with the doctor

Steps: Go to Messages, tap Compose, select doctor from list of previously seen doctors, type message, optionally attach file, send

Postcondition: Message stored encrypted, doctor notified via push

UC-P013: Display QR health card

Actor: Logged-in patient

Steps: Tap Health Card tab, see QR code displayed, brightness increases automatically, patient shows to doctor's scanner

Postcondition: No state change, audit log if doctor scans it

UC-P014: Report QR card lost or stolen

Actor: Logged-in patient

Steps: Go to Settings, tap Health Card, tap Report Lost, confirm, system immediately invalidates current QR token and issues new one, option to download/print new card

Postcondition: Old token invalidated, new token issued, audit log entry

UC-P015: Set privacy flags

Actor: Logged-in patient

Steps: Go to Settings, tap Privacy, toggle on/off for psychiatry visits, reproductive health visits, substance use visits

Postcondition: patient_profiles fields updated, hidden encounters not shown in default doctor view

UC-P016: Grant a doctor access to hidden records

Actor: Logged-in patient, currently in a consultation with a doctor

Steps: Doctor requests access, patient receives in-app prompt, patient taps Allow, doctor gains temporary session-scoped access

Postcondition: Audit log records the grant, access expires at end of session

UC-P017: Download own health record

Actor: Logged-in patient

Steps: Go to Settings, tap Download My Records, select date range or all records, tap Download, receive FHIR JSON bundle or PDF summary

Postcondition: Download prepared and delivered, audit log entry

UC-P018: Update contact information

Actor: Logged-in patient

Steps: Go to Profile, tap Edit, update phone, email, address, emergency contact, save, confirm via OTP if phone is being changed

Postcondition: profile and patient_profiles updated

UC-P019: Grant research data consent

Actor: Logged-in patient

Steps: Go to Settings, Privacy, toggle Research Data Use, read the consent explanation, confirm

Postcondition: consent_records entry created with type research_use and action granted

UC-P020: Revoke research data consent

Actor: Logged-in patient

Steps: Go to Settings, Privacy, toggle Research Data Use off, confirm

Postcondition: consent_records entry with action revoked

UC-P021: View allergy list

Actor: Logged-in patient

Steps: Go to Profile, tap Allergies, see all confirmed and unconfirmed allergies with substance name, type, and severity

UC-P022: View emergency health summary

Actor: Logged-in patient

Steps: On Health Card screen, below QR code, a compact summary shows blood group, critical allergies, and active chronic conditions — visible without navigating away

UC-P023: Change language to Urdu

Actor: Logged-in patient

Steps: Go to Settings, Language, select Urdu, app rerenders in Urdu with RTL layout

UC-P024: Receive appointment reminder

Actor: Logged-in patient

Trigger: Background job fires 24h before appointment

System action: Push notification and SMS sent with generic text "You have an upcoming appointment. Open your Health Card app for details."

Patient action: Tap notification, see appointment details

UC-P025: Receive lab result notification

Actor: Logged-in patient

Trigger: Doctor releases lab result

System action: Push notification sent

Patient action: Tap notification, navigate to lab result details, download PDF

UC-P026: Receive medication renewal reminder

Actor: Logged-in patient with expiring prescription

Trigger: Background job fires 7 days before end_date

System action: In-app notification and SMS

Patient action: Navigate to Medications, request refill

UC-P027: View doctor public profile before booking

Actor: Logged-in patient

Steps: Search doctors, tap a result, view full name, qualifications, specializations, languages spoken, clinic affiliations, consultation fee, average rating, number of reviews, and list of recent anonymized reviews

UC-P028: Register a walk-in patient (via receptionist)

Actor: Receptionist, on behalf of patient without a smartphone

Steps: Receptionist logs in, taps Register Patient, enters patient CNIC, name, phone, DOB, prints health card QR for them

Postcondition: Patient account created by receptionist, patient can later log in themselves

UC-P029: View appointment history

Actor: Logged-in patient

Steps: Go to Appointments, switch to Past tab, see all previous appointments with date, doctor, status

UC-P030: Share a specific document with a new doctor

Actor: Logged-in patient

Steps: Go to document in timeline, tap Share, system generates a time-limited link (valid 24 hours) encoded with patient auth, copy link and share via WhatsApp or SMS to the doctor

7.2 Doctor Use Cases

UC-D001: Register as a doctor

Actor: Doctor

Steps: Open app, tap Register as Doctor, enter personal CNIC, full name, phone, date of birth, enter PMDC number, select primary specialization, enter qualifications, select clinic affiliation from list, upload PMDC certificate photo, set password, confirm, submit

Postcondition: Account in PENDING status, admin notified

UC-D002: Login as doctor

Actor: Approved doctor

Precondition: Account status is active

Steps: Enter CNIC, password, receive OTP, enter OTP, land on doctor home screen

UC-D003: View today's appointment list

Actor: Logged-in doctor

Steps: Home screen shows today's appointments in time order, each showing patient name, time, type, status, tap any to see full appointment detail

UC-D004: Confirm a pending appointment

Actor: Logged-in doctor

Steps: Go to Appointments, see pending requests, tap one, review patient's reason for visit, tap Confirm

Postcondition: Appointment status changed to confirmed, patient notified

UC-D005: Decline a pending appointment

Actor: Logged-in doctor

Steps: Go to pending appointment, tap Decline, enter reason, confirm

Postcondition: Status changed to cancelled_by_doctor, patient notified with generic message

UC-D006: Scan patient QR to open their record

Actor: Logged-in doctor

Steps: Tap Scan QR on home screen, camera opens, point at patient's QR code, system validates the QR token, fetches patient profile and encounters, displays patient summary screen

Postcondition: Audit log entry: doctor X scanned patient Y's QR

UC-D007: Search patient by CNIC

Actor: Logged-in doctor

Steps: Tap Search Patient, enter CNIC manually, system finds patient, displays summary

Postcondition: Audit log entry

UC-D008: Create a new encounter

Actor: Logged-in doctor, patient record open

Steps: Tap New Encounter, system creates draft encounter linked to the patient and doctor, doctor selects appointment from today's list (if any) to link, enter chief complaint, history, examination notes, assessment, plan

UC-D009: Add a diagnosis to an encounter

Actor: Logged-in doctor, encounter in draft

Steps: In encounter form, go to Diagnoses section, tap Add Diagnosis, search ICD-10 codes by keyword or code, select one or more, set severity, set clinical status, add notes if needed

UC-D010: Prescribe medication in an encounter

Actor: Logged-in doctor

Steps: In encounter form, go to Medications section, tap Add Medication, search drug by generic or brand name, select, set dosage value, unit, route, frequency, duration in days, add patient instructions, set refills allowed, tap Save

System automatically checks allergy list and shows warning if conflict found

UC-D011: Record vitals in an encounter

Actor: Logged-in doctor or nurse under doctor account

Steps: In encounter form, go to Vitals section, enter blood pressure systolic and diastolic, pulse rate, temperature, oxygen saturation, respiratory rate, height, weight, each auto-maps to a LOINC-coded Observation resource

UC-D012: Order a lab test

Actor: Logged-in doctor, within an encounter

Steps: Go to Lab Orders section, tap New Order, search test by name or LOINC code, select lab from approved labs list, set priority (routine/urgent/stat), add clinical indication and special instructions, save

Postcondition: lab_orders record created, lab receives notification

UC-D013: Finalize an encounter

Actor: Logged-in doctor

Precondition: At least one diagnosis added

Steps: Review all entered data, tap Finalize Encounter, confirm, enter OTP for high-value action

Postcondition: Encounter status set to finalized, finalized_at timestamp set, encounter becomes read-only, patient notified of new encounter on their timeline

UC-D014: Amend a finalized encounter

Actor: Logged-in doctor

Precondition: Encounter is finalized

Steps: Open the finalized encounter, tap Create Amendment, enter mandatory reason, fill in what is being corrected, submit

Postcondition: New encounter created with amendment_of pointing to original, original unchanged

UC-D015: Review an uploaded lab result

Actor: Logged-in doctor

Trigger: Notification from lab that result is uploaded

Steps: Tap notification, open lab result, review PDF and structured values, tap Mark as Reviewed

Postcondition: lab_orders.reviewed_at set, status updated to reviewed

UC-D016: Release a lab result to a patient

Actor: Logged-in doctor

Precondition: Lab result is reviewed

Steps: On lab result screen, tap Release to Patient, optionally add a note to accompany the result, confirm

Postcondition: lab_orders.released_to_patient_at set, patient notified

UC-D017: Respond to a refill request

Actor: Logged-in doctor

Trigger: Patient submitted a refill request

Steps: Notification received, open refill request, view original prescription details, patient's note, tap Approve or Deny, if approve a new MedicationRequest is automatically created, if deny enter reason

Postcondition: Patient notified

UC-D018: Manage availability calendar

Actor: Logged-in doctor

Steps: Go to Schedule tab, tap Add Availability, choose clinic or telehealth, select day(s) of week or specific date, set start and end time, set slot duration in minutes, set max patients, save

Postcondition: doctor_availability records created, patients can now book those slots

UC-D019: Remove availability slot

Actor: Logged-in doctor

Steps: Go to Schedule, tap on an existing slot, tap Remove, confirm

Postcondition: Slot marked inactive, any unconfirmed appointments in that slot are cancelled and patients notified

UC-D020: Mark a patient checked in

Actor: Logged-in doctor (or receptionist)

Steps: On appointment detail, tap Mark Checked In

Postcondition: appointment.checked_in_at set, status changes to checked_in

UC-D021: Mark patient as no-show

Actor: Logged-in doctor

Steps: On appointment detail, after time has passed, tap Mark No-Show, confirm

Postcondition: appointment.status set to no_show, audit log entry

UC-D022: Reply to a patient message

Actor: Logged-in doctor

Steps: Go to Messages tab, see inbox sorted by last_message_at, tap a thread, read messages, type reply, optionally attach a document, send

UC-D023: Add a confirmed allergy to a patient record

Actor: Logged-in doctor, patient record open

Steps: Go to patient's Allergies section, tap Add Allergy, enter substance name, search for code, select type and category, set criticality, describe reaction, set verification status to confirmed, save

UC-D024: View consolidated medication list for patient

Actor: Logged-in doctor, patient record open

Steps: On patient summary screen, go to Medications tab, see all active MedicationRequest records from all encounters, sorted by start date, with prescribed doctor shown

UC-D025: Get allergy warning on prescribing

Actor: Logged-in doctor, mid-prescription

Precondition: Patient has a known allergy or intolerance on file

Trigger: Doctor enters a drug name that matches an allergy

System action: Warning dialog appears with allergy details and criticality, doctor must acknowledge before continuing

UC-D026: Generate prescription PDF

Actor: Logged-in doctor, encounter finalized

Steps: Open encounter, go to Medications, tap Print Prescription, system generates PDF with doctor's letterhead, digital signature, date, and all prescribed medications, doctor can download or share via WhatsApp

UC-D027: Initiate telehealth session

Actor: Logged-in doctor

Precondition: Appointment is confirmed telehealth type, appointment time has arrived

Steps: Open appointment, tap Start Video Call, system generates or opens telehealth room URL, both doctor and patient receive deep link

UC-D028: View patient timeline during consultation

Actor: Logged-in doctor, patient record open

Steps: Navigate tabs on patient profile: Overview (summary), Timeline (all encounters), Medications, Labs, Allergies, Documents, Messages

UC-D029: Set encounter confidential

Actor: Logged-in doctor, encounter in draft

Steps: In encounter form, toggle Confidential, select reason (psychiatry, reproductive, substance, HIV, other), enter note

Postcondition: Encounter marked confidential, hidden from default patient view (patient can still request access)

UC-D030: Update their own public profile

Actor: Logged-in doctor

Steps: Go to Profile, tap Edit, update bio, languages spoken, consultation fee, toggle profile_public, tap Save

7.3 Lab Worker Use Cases

UC-L001: Login as lab worker

Actor: Lab worker with approved account

Steps: Open app, enter CNIC, password, OTP, land on lab order queue

UC-L002: View pending lab orders

Actor: Logged-in lab worker

Steps: Home screen shows queue of orders for their lab, sorted STAT first then urgent then routine, each showing order number, test name, patient first name only, ordered date, priority

UC-L003: Mark sample collected

Actor: Logged-in lab worker

Steps: Tap a pending order, tap Mark Sample Collected, timestamp auto-recorded

Postcondition: lab_orders.sample_collected_at set, status to sample_collected

UC-L004: Mark order in processing

Actor: Logged-in lab worker

Steps: On order, tap Mark Processing

Postcondition: status to processing

UC-L005: Upload lab result PDF

Actor: Logged-in lab worker

Steps: On order, tap Upload Result, select PDF from device, optionally enter structured values for individual test parameters, enter technician name and machine ID, tap Submit

Postcondition: File stored encrypted in storage, lab_results record created, status to resulted, doctor notified

UC-L006: Flag a critical value

Actor: Logged-in lab worker

Steps: While entering result, toggle Critical Value flag, system adds banner, doctor is notified with higher priority notification

Postcondition: is_critical_value set to true, critical_value_notified tracking begins

UC-L007: View order details

Actor: Logged-in lab worker

Steps: Tap an order, see: order number, test name, patient first name and last initial, ordering doctor name, priority, clinical indication, special instructions (fasting required etc)

Note: Lab worker cannot see patient full CNIC, date of birth, address, or any clinical history beyond what is needed to process this specific order

7.4 Receptionist Use Cases

UC-R001: Login as receptionist

Actor: Receptionist with approved account

Steps: Open app, CNIC, password, OTP, land on clinic dashboard

UC-R002: View clinic's appointment schedule

Actor: Logged-in receptionist

Steps: Home screen shows today's appointments for all doctors at their clinic, timeline view, each showing time, doctor, patient name, status

UC-R003: Book appointment for walk-in patient

Actor: Logged-in receptionist

Steps: Tap New Appointment, search patient by CNIC (if existing) or register new patient, select doctor, view available slots, select slot, set appointment type to in-person, add reason, confirm

Postcondition: Appointment created with booked_by_role as receptionist

UC-R004: Check in a patient

Actor: Logged-in receptionist

Steps: On appointment list, find patient, tap Check In

Postcondition: Appointment status to checked_in, checked_in_at set

UC-R005: Print health card for patient

Actor: Logged-in receptionist

Steps: Search patient by CNIC, open their profile, tap Print Health Card, system generates printable QR card PDF

UC-R006: Cancel appointment

Actor: Logged-in receptionist

Steps: Find appointment, tap Cancel, enter reason, confirm

Postcondition: Status to cancelled, patient and doctor notified

7.5 Admin Use Cases

UC-A001: Review doctor registration applications

Actor: Admin

Steps: Log in to web portal, go to Approvals section, see queue of pending doctor applications, click one to view CNIC details, PMDC number, qualifications, uploaded certificate images

UC-A002: Approve a doctor

Actor: Admin

Steps: Review doctor application, verify PMDC number externally if needed, click Approve, optionally add notes

Postcondition: Doctor account status set to active, pmdc_verified set to true, doctor notified

UC-A003: Reject a doctor application

Actor: Admin

Steps: Click Reject, enter mandatory rejection reason (invalid PMDC, incomplete documents, etc), confirm

Postcondition: Doctor account status set to rejected, doctor notified with reason

UC-A004: Approve a diagnostic lab

Actor: Admin

Steps: Go to Labs queue, review application, verify license number, click Approve

Postcondition: Lab status set to active, lab workers can now receive orders

UC-A005: Suspend a user account

Actor: Admin

Precondition: Account is active

Steps: Search user by CNIC or name, open profile, click Suspend, enter mandatory reason, confirm

Postcondition: Account status to suspended, user cannot login, any active sessions invalidated

UC-A006: Reactivate a suspended account

Actor: Admin

Steps: Find suspended account, click Reactivate, enter note, confirm

Postcondition: Status to active, audit log entry

UC-A007: Issue new QR card for patient

Actor: Admin

Steps: Search patient, open profile, click Regenerate QR, confirm

Postcondition: Old QR token invalidated, new token issued, admin can print or send new card to patient

UC-A008: View audit log

Actor: Admin

Steps: Go to Audit Logs section, filter by user, resource type, date range, action type, view paginated results, each row shows timestamp, actor name, action, resource, IP address

UC-A009: Export aggregate report

Actor: Admin

Steps: Go to Reports, select report type (enrollments, appointments, lab volumes, common diagnoses), select date range and region filter, click Export as CSV or PDF

UC-A010: Create a clinic record

Actor: Admin

Steps: Go to Clinics, click Add Clinic, enter all clinic details, upload license if required, save

Postcondition: Clinic is now available in doctor affiliation searches and booking

UC-A011: Create a receptionist account

Actor: Admin

Steps: Go to Users, click Add Receptionist, enter their CNIC, name, phone, select clinic they belong to, save

Postcondition: Receptionist receives SMS with temporary credentials and OTP for first login

UC-A012: Create a lab worker account

Actor: Admin

Steps: Go to Labs, select a lab, click Add Worker, enter worker CNIC, name, phone, position title, save

Postcondition: Worker receives SMS credentials

UC-A013: View system metrics dashboard

Actor: Admin

Steps: Go to Dashboard, see real-time metrics: total registered patients, total approved doctors, appointments today, messages sent today, lab orders pending, system uptime

UC-A014: Publish new consent policy version

Actor: Super Admin

Steps: Go to Settings, Consent Templates, click New Version, write consent text in English and Urdu, publish

Postcondition: All patients are prompted on next login to accept new version

UC-A015: Configure system settings

Actor: Super Admin

Steps: Go to Settings, System Config, adjust OTP expiry minutes, login lockout threshold, session timeout durations, file upload max size, save

Postcondition: New settings apply immediately without restart

SECTION 8: ENTITY RELATIONSHIP DESCRIPTIONS (UML ERD SOURCE DATA)

8.1 All Entities and Their Primary Keys

- auth_users (id UUID PK)
- profiles (id UUID PK, FK auth_users.id)
- patient_profiles (id UUID PK, FK profiles.id)
- doctor_profiles (id UUID PK, FK profiles.id)
- lab_worker_profiles (id UUID PK, FK profiles.id)
- receptionist_profiles (id UUID PK, FK profiles.id)
- admin_profiles (id UUID PK, FK profiles.id)
- clinics (id UUID PK)
- diagnostic_labs (id UUID PK)
- doctor_clinic_affiliations (id UUID PK, FK doctor_profiles.id, FK clinics.id)
- doctor_availability (id UUID PK, FK doctor_profiles.id, FK clinics.id)
- appointments (id UUID PK, FK patient_profiles.id, FK doctor_profiles.id, FK clinics.id, FK doctor_availability.id, FK encounters.id)
- appointment_reviews (id UUID PK, FK appointments.id, FK patient_profiles.id, FK doctor_profiles.id)
- encounters (id UUID PK, FK patient_profiles.id, FK doctor_profiles.id, FK appointments.id, FK clinics.id, FK encounters.id as amendment_of)
- conditions (id UUID PK, FK encounters.id, FK patient_profiles.id, FK doctor_profiles.id)

- medication_requests (id UUID PK, FK encounters.id, FK patient_profiles.id, FK doctor_profiles.id)
- medication_refill_requests (id UUID PK, FK medication_requests.id, FK patient_profiles.id, FK doctor_profiles.id, FK medication_requests.id as resulting_medication_request_id)
- observations (id UUID PK, FK encounters.id, FK lab_results.id, FK patient_profiles.id, FK profiles.id as authored_by)
- allergies (id UUID PK, FK patient_profiles.id, FK profiles.id as recorded_by, FK encounters.id)
- lab_orders (id UUID PK, FK encounters.id, FK patient_profiles.id, FK doctor_profiles.id, FK diagnostic_labs.id)
- lab_results (id UUID PK, FK lab_orders.id, FK diagnostic_labs.id, FK lab_worker_profiles.id, FK patient_profiles.id)
- documents (id UUID PK, FK patient_profiles.id, FK encounters.id, FK profiles.id as uploaded_by)
- message_threads (id UUID PK, FK patient_profiles.id, FK doctor_profiles.id)
- messages (id UUID PK, FK message_threads.id, FK profiles.id as sender)
- audit_logs (id UUID PK, FK profiles.id as actor, FK patient_profiles.id)
- consent_records (id UUID PK, FK patient_profiles.id)
- qr_tokens (id UUID PK, FK patient_profiles.id, FK profiles.id as issued_by)
- notifications (id UUID PK, FK profiles.id as recipient)

8.2 Cardinalities

- auth_users to profiles: 1-to-1
- profiles to patient_profiles: 1-to-0-or-1 (only if role=patient)
- profiles to doctor_profiles: 1-to-0-or-1 (only if role=doctor)
- profiles to lab_worker_profiles: 1-to-0-or-1
- profiles to receptionist_profiles: 1-to-0-or-1
- profiles to admin_profiles: 1-to-0-or-1
- doctor_profiles to clinics: many-to-many via doctor_clinic_affiliations
- doctor_profiles to doctor_availability: 1-to-many
- clinics to doctor_availability: 1-to-many (clinic can be NULL for telehealth)
- patient_profiles to appointments: 1-to-many
- doctor_profiles to appointments: 1-to-many
- appointments to encounters: 1-to-0-or-1
- patient_profiles to encounters: 1-to-many
- doctor_profiles to encounters: 1-to-many
- encounters to encounters (self): 1-to-0-or-1 (amendment_of)
- encounters to conditions: 1-to-many
- encounters to medication_requests: 1-to-many
- encounters to observations: 1-to-many
- encounters to lab_orders: 1-to-many
- encounters to documents: 1-to-many
- medication_requests to medication_refill_requests: 1-to-many
- lab_orders to lab_results: 1-to-0-or-1
- lab_results to observations: 1-to-many
- patient_profiles to allergies: 1-to-many
- patient_profiles to message_threads: 1-to-many
- doctor_profiles to message_threads: 1-to-many
- message_threads to messages: 1-to-many
- patient_profiles to qr_tokens: 1-to-many (only one is_current=true at a time)
- patient_profiles to consent_records: 1-to-many
- patient_profiles to documents: 1-to-many

- diagnostic_labs to lab_orders: 1-to-many
- diagnostic_labs to lab_worker_profiles: 1-to-many
- clinics to receptionist_profiles: 1-to-many
- appointment_reviews: appointments 1-to-0-or-1

SECTION 9: SEQUENCE DIAGRAM DESCRIPTIONS

9.1 Patient Registration Sequence

Participants: PatientApp, APIGateway, AuthService, NADRAService, ProfileService, NotificationService, QRService

1. PatientApp sends POST /auth/register/patient with {cnic, fullName, phone, dob, gender, password}
2. APIGateway validates request format, forwards to AuthService
3. AuthService checks if CNIC already exists in profiles table. If exists, return 409 Conflict
4. AuthService calls NADRAService.verifyCNIC(cnic). NADRAService returns {verified: true/false, name, dob}
5. If NADRA returns verified=false, AuthService returns 422 Unprocessable Entity to PatientApp
6. AuthService creates auth_users record (email=cnic@healthcard.internal, password=bcrypt(password))
7. AuthService generates 6-digit OTP, stores in Redis with key otp:{phone} and TTL 300 seconds
8. AuthService calls NotificationService.sendSMS(phone, "Your OTP is: {otp}")
9. AuthService returns 200 with {message: "OTP sent", sessionToken: tempToken}
10. PatientApp prompts user to enter OTP
11. PatientApp sends POST /auth/verify-otp with {sessionToken, otp}
12. AuthService validates OTP from Redis, deletes it on success
13. AuthService calls ProfileService.createPatientProfile({userId, cnic, name, phone, dob, gender})
14. ProfileService creates profiles record and patient_profiles record
15. ProfileService calls QRService.issueQRToken(patientId)
16. QRService generates UUID token, stores in qr_tokens, assigns health_card_number
17. AuthService generates JWT access token and refresh token
18. AuthService calls NotificationService.sendSMS(phone, "Registration successful. Your card number is HC-...")
19. APIGateway returns {accessToken, refreshToken, profile, qrToken, healthCardNumber} to PatientApp
20. PatientApp displays health card QR code on home screen

9.2 Doctor Login with MFA Sequence

Participants: DoctorApp, APIGateway, AuthService, ProfileService, RedisCache

1. DoctorApp sends POST /auth/login with {cnic, password}
2. APIGateway forwards to AuthService
3. AuthService checks profiles table for CNIC, if not found return 401
4. AuthService checks account status. If pending, return 403 with message "Account pending approval". If suspended, return 403 with message "Account suspended"
5. AuthService verifies bcrypt(password) against stored hash. If wrong, increment failed_login_attempts, check if >= 5, if so set locked_until = now + 30min, return 401
6. AuthService checks locked_until, if still locked return 429 with retry_after
7. AuthService resets failed_login_attempts to 0
8. AuthService generates 6-digit MFA OTP, stores in Redis with key mfa:{userId} TTL 300s
9. AuthService calls NotificationService.sendSMS(phone, "Your Health Card login code is: {otp}")

10. AuthService returns {mfaRequired: true, mfaSessionToken: tempToken}
11. DoctorApp shows OTP entry screen
12. DoctorApp sends POST /auth/verify-mfa with {mfaSessionToken, otp}
13. AuthService validates OTP, deletes from Redis
14. AuthService updates profiles: last_login_at, last_login_ip, last_login_device
15. AuthService generates JWT (role=doctor, sub=userId, exp=now+3600)
16. AuthService generates refresh token, stores in Redis key refresh:{refreshToken} with TTL 7days
17. AuthService writes audit_log entry: {actor=userId, action=LOGIN, status=success}
18. Returns {accessToken, refreshToken, profile} to DoctorApp
19. DoctorApp stores tokens in secure storage (flutter_secure_storage), navigates to Doctor home

9.3 Doctor Scans Patient QR and Creates Encounter Sequence

Participants: DoctorApp, APIGateway, AuthService, PatientService, EncounterService, FHIRServer, AuditService, NotificationService

1. DoctorApp opens camera, scans QR code, reads qr_token UUID
2. DoctorApp sends GET /patients/by-qr/{qrToken} with Bearer token
3. APIGateway validates JWT, extracts doctor userId and role
4. PatientService looks up qr_tokens table for token, checks invalidated=false and is_current=true
5. PatientService fetches patient_profiles record
6. PatientService applies privacy filters: if patient has privacy flags set, excludes those encounter types from the response
7. AuditService writes: {actor=doctorId, action=READ, resource_type=patient_profile, resource_id=patientId, patient_id=patientId}
8. PatientService returns patient summary {name, dob, bloodGroup, allergies, chronicConditions, recentEncounters[last5], activeMedications, activeLabOrders}
9. DoctorApp displays patient summary screen
10. Doctor taps New Encounter
11. DoctorApp sends POST /encounters with {patientId, appointmentId(optional), encounterType, chiefComplaint}
12. EncounterService creates encounters record with status=draft
13. Returns {encounterId, status: draft}
14. Doctor fills in examination notes, diagnoses, medications, vitals, lab orders through a series of PATCH /encounters/{id} calls
15. Each PATCH validates that encounter.status=draft and encounter.doctor_id=requesting doctor. Rejects if not.
16. When medication is added, MedicationService checks allergies table for patient. If conflict found, returns 200 with {warning: {allergyName, criticality}} included in response
17. Doctor calls POST /lab-orders with {encounterId, testName, loincCode, labId, priority}
18. LabOrderService creates lab_orders record, sends notification to lab
19. Doctor taps Finalize, DoctorApp sends POST /encounters/{id}/finalize
20. EncounterService validates at least one condition exists, sets status=finalized, finalized_at=now
21. EncounterService calls FHIRServer to create FHIR Encounter, Condition, MedicationRequest, Observation resources
22. FHIRServer fires FHIR Subscription event
23. EncounterService calls NotificationService to send push to patient: "New health record added"
24. AuditService writes finalize event
25. Returns {encounter, fhirResourceIds} to DoctorApp

9.4 Lab Result Upload and Release Sequence

Participants: LabApp, APIGateway, LabService, StorageService, NotificationService, DoctorApp, PatientApp

1. LabWorker opens LabApp, views pending orders for their lab
2. LabApp sends GET /lab-orders?labId={labId}&status=processing with Bearer token
3. LabService validates lab worker's lab_id matches requested labId. Returns only orders for this lab.
4. Lab worker taps an order, marks sample collected: PATCH /lab-orders/{id}/collect
5. LabService updates sample_collected_at, status=sample_collected
6. Later, lab worker taps Upload Result on the order
7. LabApp sends multipart POST /lab-results with {labOrderId, resultFile, structuredResults[], technicianName, machineld, isCriticalValue}
8. LabService validates lab worker belongs to the lab on the order
9. StorageService stores encrypted PDF, returns file_url
10. LabService computes SHA-256 hash of file bytes, stores hash
11. LabService creates lab_results record
12. LabService updates lab_orders status to resulted, resulted_at=now
13. NotificationService sends push to ordering doctor: "Lab result uploaded for your order LO-..."
14. If isCriticalValue=true: NotificationService sends high priority notification and SMS to doctor
15. Doctor receives notification, taps it, DoctorApp opens the lab result
16. DoctorApp sends GET /lab-results/{id} with doctor's Bearer token
17. LabService validates that requesting doctor is the ordering doctor (or a treating doctor of this patient)
18. Returns {labResult, fileUrl, structuredResults, isCriticalValue}
19. Doctor reviews, taps Mark Reviewed: PATCH /lab-results/{id}/review
20. LabService sets lab_orders.reviewed_at, reviewed_by, status=reviewed
21. Doctor taps Release to Patient: PATCH /lab-results/{id}/release
22. LabService sets lab_orders.released_to_patient_at, status=released_to_patient
23. NotificationService sends push to patient: "Your test result is available"
24. Patient opens app, sees new lab result in their Labs tab

9.5 Secure Message Send Sequence

Participants: SenderApp (Patient or Doctor), APIGateway, MessageService, RedisCache, NotificationService, WebSocketServer

1. Sender opens message thread or composes new message
2. SenderApp generates a UUID as idempotency_key client-side
3. SenderApp encrypts message body client-side with shared thread key (or sends plaintext over TLS and server encrypts — simpler for prototype)
4. SenderApp sends POST /messages with {threadId, body, messageType, idempotencyKey, attachmentUrl(optional)}
5. APIGateway validates Bearer token
6. MessageService checks if messages table already has a row with this idempotencyKey. If yes, return existing message (duplicate send protection)
7. MessageService validates that sender is either the patient or doctor of this thread. Rejects if not.
8. MessageService encrypts body with AES-256-GCM, stores body_encrypted and body_iv
9. MessageService creates messages record, sets sent_at and delivered_at to now
10. MessageService updates message_threads: last_message_at, last_message_preview, increments recipient's unread_count
11. If recipient is currently connected via WebSocket: WebSocketServer pushes new message to recipient session in real time
12. If recipient is offline: NotificationService sends push notification with generic text "You have a new message in Health Card"

13. Returns {messageId, sentAt, deliveredAt} to SenderApp
14. When recipient opens the thread: PATCH /messages/read with {threadId} sets read_at on all unread messages, resets unread_count to 0

SECTION 10: STATE MACHINES

10.1 Appointment Status State Machine

States: pending, confirmed, checked_in, in_progress, completed, cancelled_by_patient, cancelled_by_doctor, no_show, rescheduled

Transitions:

- pending → confirmed: Doctor taps Confirm
- pending → cancelled_by_doctor: Doctor declines or removes availability
- pending → cancelled_by_patient: Patient cancels (>2h before)
- confirmed → checked_in: Doctor or receptionist marks arrived
- confirmed → cancelled_by_patient: Patient cancels (>2h before)
- confirmed → cancelled_by_doctor: Doctor cancels
- confirmed → no_show: Doctor marks no-show after appointment time passes
- checked_in → in_progress: Doctor opens encounter for this appointment
- in_progress → completed: Doctor finalizes encounter
- pending → rescheduled: Patient reschedules (creates new appointment in pending, marks this one rescheduled)
- confirmed → rescheduled: Patient reschedules

Terminal states: completed, cancelled_by_patient, cancelled_by_doctor, no_show, rescheduled

10.2 Encounter Status State Machine

States: draft, finalized, amended

Transitions:

- (new) → draft: Doctor creates encounter
- draft → finalized: Doctor submits with at least one condition
- finalized → amended: Doctor creates amendment (original stays finalized, new encounter in draft marked as amendment_of original, then finalized)

Note: There is no transition from finalized back to draft. The only way to correct a finalized encounter is to create a new amendment encounter.

10.3 Lab Order Status State Machine

States: ordered, sample_collected, processing, result, reviewed, released_to_patient, cancelled

Transitions:

- ordered → sample_collected: Lab worker marks collection
- sample_collected → processing: Lab worker marks processing start
- processing → result: Lab worker uploads result
- result → reviewed: Doctor reviews the result

- reviewed → released_to_patient: Doctor releases
- ordered → cancelled: Doctor or admin cancels order before sample collected
- sample_collected → cancelled: Only admin can cancel after this point

10.4 Doctor Account Status State Machine

States: pending, active, suspended, rejected, deactivated

Transitions:

- pending → active: Admin approves
- pending → rejected: Admin rejects with reason
- active → suspended: Admin suspends with reason
- suspended → active: Admin reactivates
- active → deactivated: Doctor or admin deactivates account
- rejected → pending: Doctor resubmits (creates new application, old one stays rejected)

10.5 Medication Request Status State Machine

States: draft, active, on_hold, stopped, completed, cancelled, entered_in_error

Transitions:

- draft → active: Encounter finalized
- active → on_hold: Doctor places on hold
- active → stopped: Doctor stops mid-course
- active → completed: Duration elapsed or doctor marks complete
- active → cancelled: Doctor cancels prescription
- any → entered_in_error: Doctor marks as error (creates amendment encounter)
- on_hold → active: Doctor resumes

10.6 QR Token State Machine

States: active, invalidated

Transitions:

- (issued) → active: Token issued on registration or regeneration
- active → invalidated: Patient reports lost/stolen, or admin action, or new token issued (previous becomes invalidated)

At any point in time, a patient has exactly one active QR token (is_current=true, invalidated=false).

SECTION 11: API SURFACE OVERVIEW

11.1 Authentication Endpoints

POST /auth/register/patient — Create patient account (public)

POST /auth/register/doctor — Submit doctor application (public)

POST /auth/verify-otp — Verify registration OTP
POST /auth/login — Initiate login (returns mfa required)
POST /auth/verify-mfa — Complete MFA, receive tokens
POST /auth/refresh — Exchange refresh token for new access token
POST /auth/logout — Invalidate session
POST /auth/forgot-password — Initiate password reset via OTP
POST /auth/reset-password — Complete password reset

11.2 Patient Endpoints (role: patient)

GET /me/profile — Own profile
PATCH /me/profile — Update own contact info
GET /me/health-card — QR token and health card number
POST /me/health-card/report-lost — Invalidate and reissue QR
GET /me/timeline — Paginated encounter list
GET /me/timeline/:encounterId — Single encounter detail
GET /me/medications — Active medication list
POST /me/medications/:id/refill-request — Submit refill
GET /me/labs — Lab order and result list
GET /me/labs/:id — Single lab result detail
GET /me/labs/:id/download — Signed URL for result PDF
GET /me/allergies — Allergy list
GET /me/appointments — Appointment list
POST /me/appointments — Book new appointment
PATCH /me/appointments/:id/cancel — Cancel
PATCH /me/appointments/:id/reschedule — Reschedule
POST /me/appointments/:id/review — Submit rating
GET /me/messages — Thread list
GET /me/messages/:threadId — Messages in thread
POST /me/messages — Send message
PATCH /me/messages/read — Mark as read
GET /me/documents — Document list
GET /me/documents/:id/download — Signed download URL
GET /me/notifications — Notification history
PATCH /me/notifications/:id/read — Mark notification read
GET /me/consent — Consent record history
PATCH /me/consent — Update consent

11.3 Doctor Endpoints (role: doctor)

GET /patients/by-qr/:token — Fetch patient by QR token
GET /patients/by-cnic — Search by CNIC
GET /patients/:id — Patient summary

GET /patients/:id/encounters — Patient encounter history
GET /patients/:id/medications — Patient medication list
GET /patients/:id/labs — Patient lab list
GET /patients/:id/allergies — Patient allergy list
GET /patients/:id/documents — Patient documents
POST /encounters — Create draft encounter
GET /encounters/:id — Get encounter
PATCH /encounters/:id — Update draft encounter
POST /encounters/:id/finalize — Finalize
POST /encounters/:id/amend — Create amendment
POST /encounters/:id/conditions — Add condition
POST /encounters/:id/medications — Add medication request
POST /encounters/:id/observations — Add observation
POST /encounters/:id/vitals — Record vitals (maps to observations)
POST /lab-orders — Create lab order
GET /lab-orders — Doctor's lab orders
PATCH /lab-orders/:id/review — Mark reviewed
PATCH /lab-orders/:id/release — Release to patient
GET /me/doctor-profile — Doctor's own profile
PATCH /me/doctor-profile — Update profile
GET /me/availability — Availability slots
POST /me/availability — Add availability
PATCH /me/availability/:id — Edit slot
DELETE /me/availability/:id — Remove slot
GET /me/appointments — Doctor's appointments
PATCH /me/appointments/:id/confirm — Confirm
PATCH /me/appointments/:id/cancel — Cancel
PATCH /me/appointments/:id/check-in — Mark checked in
PATCH /me/appointments/:id/no-show — Mark no-show
GET /me/messages — Message inbox
POST /me/messages — Send message
GET /me/lab-results — Incoming results for review
POST /me/refill-requests/:id/respond — Approve or deny refill

11.4 Lab Worker Endpoints (role: lab_worker)

GET /lab-orders — Queue for their lab only
PATCH /lab-orders/:id/collect — Mark collected
PATCH /lab-orders/:id/process — Mark processing
POST /lab-results — Upload result
PATCH /lab-results/:id — Update result

11.5 Receptionist Endpoints (role: receptionist)

GET /clinic/appointments — Clinic's appointment schedule
POST /clinic/appointments — Book on behalf of patient
PATCH /clinic/appointments/:id/cancel — Cancel
PATCH /clinic/appointments/:id/check-in — Check in patient
GET /clinic/patients/by-cnic — Search patient for check-in
POST /clinic/patients/register — Register walk-in patient
GET /clinic/patients/:id/health-card — Patient QR for printing

11.6 Admin Endpoints (role: admin)

GET /admin/applications/doctors — Pending doctor queue
GET /admin/applications/doctors/:id — Application detail
POST /admin/applications/doctors/:id/approve — Approve
POST /admin/applications/doctors/:id/reject — Reject with reason
GET /admin/applications/labs — Pending lab queue
POST /admin/applications/labs/:id/approve — Approve lab
POST /admin/applications/labs/:id/reject — Reject
GET /admin/users — Search any user
PATCH /admin/users/:id/suspend — Suspend with reason
PATCH /admin/users/:id/reactivate — Reactivate
POST /admin/users/receptionist — Create receptionist
POST /admin/users/lab-worker — Create lab worker
GET /admin/clinics — List clinics
POST /admin/clinics — Create clinic
PATCH /admin/clinics/:id — Update clinic
GET /admin/audit-logs — Search audit logs
GET /admin/reports/enrollments — Enrollment stats
GET /admin/reports/appointments — Appointment stats
GET /admin/reports/labs — Lab volume stats
GET /admin/qr/:patientId/reissue — Reissue QR
GET /admin/system-config — Get settings
PATCH /admin/system-config — Update settings

SECTION 12: SECURITY MODEL

12.1 Authentication Flow

Every request to a protected endpoint must carry an Authorization header with a Bearer JWT.

The JWT payload contains: sub (user UUID), role (patient/doctor/etc), jti (unique token ID), iat (issued at), exp (expires at), aud (audience: healthcard.api).

On every request: APIGateway validates JWT signature with the public key. Checks exp is in future. Checks jti has not been revoked (revoked JTIs stored in Redis for the remaining lifetime of the token). Extracts role and sub.

The application service then loads the user's current status from the database (not just from the token) to detect suspended accounts that were suspended after the token was issued.

12.2 Authorization (RBAC)

Resource access is checked at the service layer, not just the gateway. For example: a doctor requesting GET /patients/:id/encounters fetches the encounters but then filters out encounters where the requesting doctor is not the author AND where the patient's privacy settings flag that encounter type as hidden AND where is_confidential=true — unless the patient has explicitly granted access.

Permission checks are always: is the actor's role allowed to perform this action on this resource type, AND is this specific actor allowed to access this specific instance of the resource.

12.3 Sensitive Data Handling

CNIC is stored hashed (bcrypt) in auth layer. A secondary HMAC hash is stored for indexed lookup. Plaintext CNIC is never stored in the database after the hash is computed.

Message bodies are encrypted at application layer. Even database admins cannot read messages without the application encryption key.

Lab result PDFs are stored encrypted. File URLs are pre-signed and expire after 15 minutes. The same URL cannot be shared and used later.

File integrity: every uploaded file has its SHA-256 hash stored. On download, the system recomputes the hash and compares. If they differ, the file has been tampered with and the download is rejected.

12.4 Network Security

No service is publicly accessible except the API Gateway.

FHIR server, database, Redis, RabbitMQ: all in a private VPC subnet.

API Gateway sits in the public subnet.

NADRA integration is called from a dedicated integration microservice in the private subnet via an outbound NAT gateway.

Database connections use SSL certificates. The application service holds the certificate and validates it on every connection.

SECTION 13: ROLE AND PERMISSION MATRIX

Action	Patient	Doctor	Lab Worker	Receptionist	Admin
Read own profile	Yes	Yes	Yes	Yes	Yes
Read other patient's profile	No	Yes (limited)	No	Yes (demographics only)	Yes (limited)
Read own encounters	Yes	Yes (own authored)	No	No	No

Action	Patient	Doctor	Lab Worker	Receptionist	Admin
Read other patient's encounters	No	Yes (treating doctor)	No	No	No
Create encounter	No	Yes	No	No	No
Finalize encounter	No	Yes (own draft)	No	No	No
Add condition to encounter	No	Yes	No	No	No
Prescribe medication	No	Yes	No	No	No
Read medication list	Yes (own)	Yes (any patient)	No	No	No
Request refill	Yes (own)	No	No	No	No
Approve refill	No	Yes	No	No	No
Create lab order	No	Yes	No	No	No
View lab order queue	No	Yes (own orders)	Yes (own lab)	No	Yes (all)
Upload lab result	No	No	Yes	No	No
Release lab result to patient	No	Yes	No	No	No
View own lab results	Yes	N/A	No	No	No
Book appointment	Yes	No	No	Yes	No
Confirm appointment	No	Yes	No	No	No
Cancel appointment	Yes (own)	Yes (own schedule)	No	Yes (at clinic)	Yes
Check in patient	No	Yes	No	Yes	No
Send message	Yes (to treating doctors)	Yes (to own patients)	No	No	No
Read messages	Yes (own threads)	Yes (own threads)	No	No	No
Approve doctor account	No	No	No	No	Yes
Suspend account	No	No	No	No	Yes
View audit logs	No	No	No	No	Yes
Issue QR card	No	No	No	Yes (print only)	Yes
View aggregate reports	No	Yes (own patients)	No	No	Yes
Configure system	No	No	No	No	Super Admin only

SECTION 14: NOTIFICATION AND EVENT CATALOGUE

14.1 All Notification Types

NT-001: appointment_reminder_24h — Fires 24 hours before appointment. Recipient: patient.

NT-002: appointment_reminder_1h — Fires 1 hour before. Recipient: patient.

NT-003: appointment_confirmed — Doctor confirmed booking. Recipient: patient.

NT-004: appointment_cancelled_by_doctor — Doctor cancelled. Recipient: patient.

NT-005: appointment_cancelled_by_patient — Patient cancelled. Recipient: doctor.

NT-006: new_appointment_request — Patient submitted booking. Recipient: doctor.

NT-007: appointment_checked_in — Patient arrived. Recipient: doctor (if using app to manage queue).

NT-008: appointment_no_show — Doctor marked no-show. Recipient: patient (with rebook prompt).

NT-009: new_message — New message in thread. Recipient: the other party.

NT-010: new_encounter_on_timeline — Doctor finalized an encounter. Recipient: patient.

NT-011: lab_result_uploaded — Lab worker uploaded result. Recipient: ordering doctor.

NT-012: lab_result_critical — Critical value flagged. Recipient: ordering doctor (high priority + SMS).

NT-013: lab_result_released — Doctor released result. Recipient: patient.

NT-014: refill_request_submitted — Patient requested refill. Recipient: doctor.

NT-015: refill_request_approved — Doctor approved. Recipient: patient.

NT-016: refill_request_denied — Doctor denied. Recipient: patient.

NT-017: medication_renewal_reminder_7d — 7 days to prescription end. Recipient: patient.

NT-018: medication_renewal_reminder_3d — 3 days to end. Recipient: patient.

NT-019: new_lab_order — Lab order sent to their lab. Recipient: lab workers at that lab.

NT-020: account_status_changed — Registration approved/rejected/suspended. Recipient: affected user.

NT-021: new_doctor_application — Doctor submitted registration. Recipient: admin.

NT-022: new_lab_application — Lab submitted registration. Recipient: admin.

NT-023: qr_card_reissued — QR token invalidated and new one issued. Recipient: patient.

NT-024: new_consent_version — New consent policy published. Recipient: all patients (on next login).

NT-025: document_shared_with_you — Patient shared a document with doctor. Recipient: doctor.

14.2 Notification Content Rules

All notification bodies must use only generic text. The following are PROHIBITED in any notification body or title: patient name, diagnosis name, medication name, doctor name, appointment type (no "psychiatry appointment"), lab test name, condition category. The notification text must only direct the user to open the app. For example: "You have a new update in your Health Card. Open the app to view." On-tap deep link in the notification payload carries the relevant screen route, but the text itself reveals nothing.

SECTION 15: AUDIT AND COMPLIANCE RULES

15.1 Events That Must Be Audit Logged

Every one of these events creates an append-only row in audit_logs:

- User login (success and failure)
- User logout
- Account lockout triggered
- Password change
- MFA code sent
- MFA code verified
- QR code scanned (which doctor, which patient)
- Patient record viewed (any GET that returns patient clinical data)

- Encounter created, updated, finalized, amended
- Condition created, updated
- Medication prescribed, updated, cancelled
- Observation recorded
- Allergy recorded, updated
- Lab order created, cancelled
- Lab result uploaded
- Lab result reviewed
- Lab result released to patient
- Message sent
- Document uploaded
- Document downloaded
- Appointment booked, confirmed, cancelled, rescheduled
- Refill request submitted, approved, denied
- QR token scanned
- QR token invalidated
- QR token issued
- Account status changed
- Doctor application approved or rejected
- Lab application approved or rejected
- Account suspended or reactivated
- Consent granted or revoked
- System configuration changed
- Admin user created
- Export report generated

15.2 Data Retention Policy

Patient clinical records: retained for minimum 10 years per Pakistani medical records law. Even if patient deactivates account.

PII (name, phone, address): anonymized on account deletion request (replace with hash, not deleted).

Audit logs: retained for minimum 7 years.

Messages: retained for 5 years.

Notifications: retained for 1 year.

OTP codes: deleted immediately on use or expiry (Redis TTL handles this).

Session tokens: deleted on logout or expiry.

Uploaded files: retained as long as the associated record exists. Never deleted independently.

15.3 PDPB Compliance Checklist

Minimum data collection: only fields necessary for the stated purpose are collected. No speculative data collection.

Explicit consent: patients accept consent at registration. Consent version is recorded.

Right to access: GET /me endpoints allow patient to access all their data.

Right to erasure: implemented as anonymization of PII + account deactivation, retaining medical records.

Data portability: GET /me/export returns FHIR bundle of all clinical records.

Breach notification: automated alerts within 1 hour of detected breach to admin, within 72 hours to affected patients.

Data residency: enforced at infrastructure level, not application level.

Third-party processing: all vendors sign DPAs before integration.

SECTION 16: IMPLEMENTATION PHASES

Phase 1 — Foundation (Months 1-2)

Database setup: Create all schemas, tables, indexes, RLS policies, audit trigger functions.

Auth service: CNIC+OTP registration, login, MFA, JWT, session management.

Profile management: Create and fetch patient, doctor, lab worker, receptionist, admin profiles.

NADRA integration stub: Fake verification for prototype (CNIC format check only), real API in Phase 3.

QR token service: Generate, issue, invalidate tokens, generate health card numbers.

Admin portal skeleton: Doctor application queue, approve/reject flow.

Flutter app skeleton: GoRouter setup, login screen, role-based navigation, patient home, doctor home.

Phase 2 — Core Clinical (Months 3-4)

Encounter management: Full CRUD for draft encounters, finalize, amendment.

Conditions module: Add ICD-10 diagnoses to encounters.

Medications module: Prescribe with full dosage fields, allergy conflict check.

Observations module: Vitals recording, lab observation linking.

Allergies module: Record and display.

Patient timeline: Full encounter history, filter, search.

Doctor patient access: QR scan, CNIC search, patient summary screen.

Appointment scheduling: Doctor availability management, patient booking, confirmation flow.

Admin clinic management: Create and manage clinic records, lab records.

Phase 3 — Lab Workflow and Messaging (Months 5-6)

Lab order module: Doctor creates orders in encounter, routes to lab.

Lab worker app: Order queue, sample collection, result upload, critical value flagging.

Lab result review: Doctor review and release flow.

Secure messaging: Thread management, message send/receive, WebSocket real-time delivery, push fallback.

Refill request flow: Patient submits, doctor approves/denies, new prescription auto-created.

Notification service: All 25 notification types implemented with background job scheduler.

Document management: Upload, storage, download with signed URLs, integrity check.

Phase 4 — Integration and Hardening (Months 7-8)

Real NADRA integration: Replace stub with live API.

FHIR server: Deploy HAPI FHIR, sync clinical data as FHIR resources, enable subscriptions.

Telehealth integration: Video room generation for telehealth appointments.

Prescription PDF generation: Digital signature, printable format.

Full audit logging: All events wired to audit service.

Security hardening: Penetration test, dependency scan, key rotation setup.

Offline mode: Local encrypted SQLite cache for patient and doctor apps.

Urdu localisation: All strings translated, RTL layout tested.

Performance optimisation: Index analysis, query plans reviewed, caching layer tuned.

Phase 5 — Pilot and Scale (Months 9-11)

Pilot with selected clinics and labs.

User acceptance testing with real doctors and patients.

Feedback integration and UX refinement.

Load testing to 10,000 concurrent users.

CI/CD pipeline finalised.

Documentation for onboarding new clinics and labs.

Training materials in Urdu and English.

Rollout planning for additional cities and provinces.

End of System Design Document

Total sections: 16 | Total functional requirements: 140 | Total non-functional requirements: 60 | Total use cases: 77 detailed | Total database tables: 28 | Total notification types: 25